

Bandit Level 0-Level 1

Ssh(secure shell) và sẽ sử dụng dưới dạng lệnh:

Ssh người dùng@tên miền (ví dụ bandit.labs.ovverthewire.org) hoặc địa chỉ ip máy chủ (ví dụ 192.168.1.1)



The goal of this level is for you to log into the game using SSH. The host to which you need to connect is **bandit.labs.overthewire.org**, on port 2220. The username is **bandit0** and password is **bandit0**. Once logged in, go to the **Level 1** page to find out how to beat Level 1.

Ở level 0 có cổng port 2220 thì sẽ được ghi chỉ định là -p 2220 và có username là bandit0 và cũng là password khi truy cập vào Level 0 và khi lên các level tiếp theo thì username lần password sẽ lần lượt cũng sẽ thay đổi ví dụ bandit1,bandit2...

Sử dụng lệnh ssh để truy cập vào Level 0 là ssh bandit0@bandit.labs.overthewire.org -p 2220 để truy cập vào.

```
(kali㉿kali)-[~]  
$ ssh bandit0@bandit.labs.overthewire.org -p 2220  
  
bandit0  
  
This is an OverTheWire game server.  
More information on http://www.overthewire.org/wargames  
  
backend: gibbon-1  
bandit0@bandit.labs.overthewire.org's password: █
```

sử dụng password như đã nói ở trên là bandit0 để truy cập vào:

```
bandit0@bandit: ~$
Session Actions Edit View Help
with easily guessable or short names will be periodically deleted! The /tmp
directory is regularly wiped.
Please play nice:

* don't leave orphan processes running
* don't leave exploit-files laying around
* don't annoy other players
* don't post passwords or spoilers
* again, DONT POST SPOILERS!
  This includes writeups of your solution on your blog or website!

--[ Tips ]--

This machine has a 64bit processor and many security-features enabled
by default, although ASLR has been switched off. The following
compiler flags might be interesting:

-m32          compile for 32bit
-fno-stack-protector  disable ProPolice
-Wl,-z,norelro  disable relro

In addition, the execstack tool can be used to flag the stack as
executable on ELF binaries.

Finally, network-access is limited for most levels by a local
firewall.

--[ Tools ]--

For your convenience we have installed a few useful tools which you can find
in the following locations:

* gef (https://github.com/hugsy/gef) in /opt/gef/
* pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
* gdbinit (https://github.com/gdbinit/gdbinit) in /opt/gdbinit/
* pwntools (https://github.com/Gallopsled/pwntools)
* radare2 (http://www.radare.org/)

--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

Enjoy your stay!
bandit0@bandit:~$
```

Sau khi nhập đúng mật khẩu, hệ thống sẽ kết nối thành công và in ra màn hình một Banner đăng nhập (Message of the Day) rất dài. Như ta có thể thấy, banner này hiển thị các thông tin chào mừng, nội quy của server (*Please play nice*), các gợi ý về compiler flags và danh sách đường dẫn của các công cụ (*Tools*) đã được cài đặt sẵn. Cuối cùng, dấu nhắc lệnh chuyển thành `bandit0@bandit:~$`, xác nhận ta đã ở bên trong server.

Sau khi truy cập vào hệ thống bandit thì theo đề bài ta sẽ tìm một file tên `readme` được nằm ở thư mục home directory

Bandit Level 0 → Level 1

Level Goal

The password for the next level is stored in a file called `readme` located in the home directory. Use this password to log into bandit1 using SSH. Whenever you find a password for a level, use SSH (on port 2220) to log into that level and continue the game.

Commands you may need to solve this level

`ls, cd, cat, file, du, find`

Và dựa trên gợi ý mà đề bài Level 0-1 đã đưa thì ta sẽ lần sử dụng các lệnh

`ls` (list) dùng để liệt kê các file và thư mục nằm trong thư mục cụ thể

```
bandit0@bandit:~$ ls
readme
```

Cat dùng để xem toàn thông tin có trong mục readme từ đó tácó password là 6y2kwnwK6grgvwvpvLaa2T1cpFEKOhNR

```
bandit0@bandit:~$ cat readme
Congratulations on your first steps into the bandit game!!
Please make sure you have read the rules at https://overthewire.org/rules/
If you are following a course, workshop, walkthrough or other educational activity,
please inform the instructor about the rules as well and encourage them to
contribute to the OverTheWire community so we can keep these games free!

The password you are looking for is: 6y2kwnwK6grgvwvpvLaa2T1cpFEKOhNR
bandit0@bandit:~$
```

Bandit Level 1 → Level 2

Ở level này tácó nhiệm vụ là tìm một file có tên là `.-` rồi xem trong file đó có gì

Bandit Level 1 → Level 2

Level Goal

The password for the next level is stored in a file called `.-` located in the home directory

Commands you may need to solve this level

`ls`, `cd`, `cat`, `file`, `du`, `find`

Đầu tiên dùng lệnh `ls` để ra tên file –

```
bandit1@bandit:~$ ls
```

Sau đó ta sẽ dùng lệnh `cat ./-`

`.` là dùng để chỉ chỗ thư mục mà ta đang đứng hiện tại

`/` là để chỉ các ký tự phân cách thư mục

`-` là tên thư mục mà ta định xem

```
bandit1@bandit:~$ cat ./-
PK8fYLZg2hnHSz83plBL1iEPKdD3QToB
```

Ngoài ra tácó thể dùng lệnh `cat /home/bandit1/.-`

Y chang cách dùng `cat ./-` nhưng lần này ta sẽ chỉ địa chỉ chính xác

Gõ lệnh pwd để biết chính xác mình đang ở đâu

```
bandit1@bandit:~$ pwd
/home/bandit1
```

sau đó nối tên file - vào đuôi của đường dẫn đó từ đó ta có thể xem được mật khẩu cho Level tiếp theo.

```
bandit1@bandit:~$ cat /home/bandit1/-
PK8fYLZg2hnHSz83p1BL1iEPKdD3QToB
```

Bandit level 2-level 3

Dùng ls để xác định tên file

```
bandit2@bandit:~$ ls
--spaces in this filename--
```

Dựa vào đây <https://www.geeksforgeeks.org/linux-unix/cat-command-in-linux-with-examples/>

Cụ thể là dấu -- có nghĩa là kể từ sau dấu -- này, bất kể ký tự nào đi theo sau cũng đều là tên file

5. Open Files Whose Names Start with a Dash Using --

When a filename begins with a dash (-), Linux may treat it as a command option. The -- option is used with cat to tell the system that what follows is a filename, not an option.

Syntax:

```
cat -- file_name
```

Example:

```
cat -- -jayesh2
```

```
administrator@GFG19566-LAPTOP:~/practice$ cat -jayesh2
cat: invalid option -- 'j'
Try 'cat --help' for more information.
administrator@GFG19566-LAPTOP:~/practice$ cat -- "-jayesh2"
Hello GeeksforGeeks
```

displaying content inside a file starting with '-'

Từ đó có lệnh cat -- "--spaces in this filename--" và xem được password để làm level 3

```
bandit2@bandit:~$ cat -- "--spaces in this filename--"
7ZZ2LFrykP2zEyvBl4m3clcL7tGYJPME
```

Ngoài ra còn cách để xử lý khoảng trống tên file ta dùng \ để nó sẽ coi khoảng trắng ở phía sau là một phần của tên file nếu không thì tên file sẽ bị coi thành 4 phần riêng biệt nếu có khoảng trắng, ở đây là spaces, in, this, filename.

```
bandit2@bandit:~$ cat ./--spaces\ in\ this\ filename--
7ZZ2LFrykP2zEyvBl4m3clcL7tGYJPME
```

Bandit Level 3 → Level 4

Level Goal

The password for the next level is stored in a hidden file in the **inhere** directory.

Commands you may need to solve this level

`ls` , `cd` , `cat` , `file` , `du` , `find`

Ở level này ta dùng `ls` để hiện tên thư mục

```
bandit3@bandit:~$ ls  
inhere
```

Và dùng `ls -l` để xem thông tin thư mục lần cuối đã được sửa đổi

```
bandit3@bandit:~$ ls -l  
total 4  
drwxr-xr-x 2 root root 4096 Jun 24 14:59 inhere
```

`drwxr-xr-x`: Loại file và các quyền truy cập. Chữ d đầu tiên nghĩa là thư mục, dấu - nghĩa là file thường. Dãy ký tự đằng sau là quyền r là Đọc, w là Ghi, x là Thực thi của Chủ sở hữu, Nhóm, và Người khác.

2: Số lượng trỏ đến thư mục này.

root: Tên của người dùng là chủ sở hữu file.

root: Tên của nhóm sở hữu file Group.

4096: Kích thước của file/thư mục tính bằng byte.

Jun 24 14:59: Thời gian file được chỉnh sửa lần cuối.

inhere: Tên của thư mục.

Sau dùng lệnh `cd` để truy cập vào thư mục

```
bandit3@bandit:~$ cd inhere
```

Sau đó dùng lệnh `ls -a`

`ls -a` là lệnh dùng để hiển thị tất cả các file có trong thư mục kể cả có bị ẩn đi

```
bandit3@bandit:~/inhere$ ls -a
```

Sau gõ lệnh thì có kết quả như sau

```
bandit3@bandit:~/inhere$ ls -a
.  ..  ... Hiding-From-You
```

Rồi dùng lệnh `cat` để đọc file và lấy được password ở level tiếp theo

```
bandit3@bandit:~/inhere$ cat ... Hiding-From-You
xzTXq1rDJQVVAzdv5cHq1TQytTWufAMq
```

Bandit Level 4- Level 5

Ta dùng các lệnh sau để xác định có bao nhiêu file trong thư mục

```
bandit4@bandit:~$ ls
inhere
bandit4@bandit:~$ cd inhere
bandit4@bandit:~/inhere$ ls -a
-file00 -file01 -file02 -file03 -file04 -file05 -file06 -file07 -file08 -file09 . ..
```

Dùng lệnh `cat ./*` để xem thông tin tất cả file

```
bandit@bandit:~/inhere$ cat /dev/urandom | tr -dc 'a-z0-9' | fold -w 64 | xargs sha1sum
```

Do hầu hết tất cả file đều ko xem được mà đề kêu là pass ở trong file mà đọc được thì file thường sẽ thuộc định dạng mà người xem có thể đọc thể kiểu như file ACII

Sử dụng lệnh `ls -a` trong thư mục `inhere`, ta thấy có 10 file bị ẩn (từ `-file00` đến `-file09`). ta sử dụng lệnh `file ./*` để kiểm tra định dạng của toàn bộ các file này.

Cơ chế của lệnh: Lệnh này không dựa vào đuôi mở rộng để phán đoán. Thay vào đó, nó đọc một đoạn dữ liệu ở phần đầu của tệp (gọi là Magic Bytes hoặc Header) và đối chiếu với cơ sở dữ liệu hệ thống để xác định chính xác cấu trúc bên trong là văn bản thuần túy (ASCII text) hay nhị phân (binary/data). Dấu * đại diện cho tất cả

```
bandit4@bandit:~/inhere$ file ./-file00: data
./-file01: data
./-file02: OpenPGP Secret Key
./-file03: data
./-file04: data
./-file05: data
./-file06: Non-ISO extended-ASCII text, with NEL line terminators
./-file07: ASCII text
./-file08: data
./-file09: data
```

Kết quả lệnh file cho thấy ./-file07: ASCII text, trong khi các file khác là data. Do đó, ta dùng lệnh cat ./-file07 để đọc file duy nhất chứa văn bản đọc được (human-readable) và lấy mật khẩu 6C7h9GD8M6ai5nr7wo1RonrzFjj9yIrG.

Và dùng lệnh cat ./file07 để xem file07 có pass ở trong đó ko

```
bandit4@bandit:~/inhere$ cat ./-file07
6C7h9GD8M6ai5nr7wo1RonrzFjj9yIrG
```

Level 5-6

Truy cập vào thư mục `inhere` và dùng lệnh `ls -a` và `ls -l` để xem tất cả các thông tin có trong thư mục

```
bandit5@bandit:~$ ls
inhere
bandit5@bandit:~$ cd inhere
bandit5@bandit:~/inhere$ ls -a
.  maybehere00  maybehere02  maybehere04  maybehere06  maybehere08  maybehere10  maybehere12  maybehere14  maybehere16  maybehere18
.. maybehere01  maybehere03  maybehere05  maybehere07  maybehere09  maybehere11  maybehere13  maybehere15  maybehere17  maybehere19
bandit5@bandit:~/inhere$ ls -l
total 80
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere00
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere01
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere02
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere03
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere04
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere05
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere06
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere07
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere08
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere09
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere10
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere11
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere12
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere13
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere14
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere15
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere16
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere17
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere18
drwxr-x-- 2 root bandit5 4096 Jun 24 14:59 maybehere19
```

Dựa vào đề bài

Bandit Level 5 → Level 6

Level Goal

The password for the next level is stored in a file somewhere under the **inhere** directory and has all of the following properties:

- human-readable
- 1033 bytes in size
- not executable

Gõ lệnh `find --help` để tìm gợi ý


```
bandit5@bandit: ~/inhere$ find --help
Usage: find [-H] [-L] [-P] [-Olevel] [-D debugopts] [path... ] [expression]

Default path is the current directory; default expression is -print.
Expression may consist of: operators, options, tests, and actions.

Operators (decreasing precedence; -and is implicit where no others are given):
  ( EXPR )  ! EXPR  -not EXPR  EXPR1 -a EXPR2  EXPR1 -and EXPR2
  EXPR1 -o EXPR2  EXPR1 -or EXPR2  EXPR1 , EXPR2

Positional options (always true):
  -daystart -follow -nowarn -regextype -warn

Normal options (always true, specified before other expressions):
  -depth -files0-from FILE -maxdepth LEVELS -mindepth LEVELS
  -mount -noleaf -xdev -ignore_readdir_race -noignore_readdir_race

Tests (N can be +N or -N or N):
  -amin N -anewer FILE -atime N -cmin N -cnewer FILE -context CONTEXT
  -ctime N -empty -false -fstype TYPE -gid N -group NAME -ilname PATTERN
  -iname PATTERN -inum N -iwholename PATTERN -iregex PATTERN
  -links N -lname PATTERN -mmin N -mtime N -name PATTERN -newer FILE
  -nouser -nogroup -path PATTERN -perm [-/]MODE -regex PATTERN
  -readable -writable -executable
  -wholename PATTERN -size N[bcwkMG] -true -type [bcdpflsD] -uid N
  -used N -user NAME -xtype [bcdpfls]

Actions:
  -delete -print0 -printf FORMAT -fprintf FILE FORMAT -print
  -print0 FILE -fprintf FILE -ls -fls FILE -prune -quit
  -exec COMMAND ; -exec COMMAND {} + -ok COMMAND ;
  -execdir COMMAND ; -execdir COMMAND {} + -okdir COMMAND ;

Other common options:
  --help                display this help and exit
  --version              output version information and exit

Valid arguments for -D:
exec, opt, rates, search, stat, time, tree, all, help
Use '-D help' for a description of the options, or see find(1)

Please see also the documentation at https://www.gnu.org/software/findutils/.
You can report (and track progress on fixing) bugs in the "find"
program via the GNU findutils bug-reporting page at
https://savannah.gnu.org/bugs/?group=findutils or, if
you have no web access, by sending email to <bug-findutils@gnu.org>.
```

ở Phần operations

Ký hiệu ! hoặc -not đi trước một biểu thức (EXPR) sẽ đảo ngược ý nghĩa của biểu thức đó (ví dụ: đang tìm file chạy được thành file KHÔNG chạy được).

ở phần test

```
Tests (N can be +N or -N or N):
  -amin N -anewer FILE -atime N -cmin N -cnewer FILE -context CONTEXT
  -ctime N -empty -false -fstype TYPE -gid N -group NAME -ilname PATTERN
  -iname PATTERN -inum N -iwholename PATTERN -iregex PATTERN
  -links N -lname PATTERN -mmin N -mtime N -name PATTERN -newer FILE
  -nouser -nogroup -path PATTERN -perm [-/]MODE -regex PATTERN
  -readable -writable -executable
  -wholename PATTERN -size N[bcwkMG] -true -type [bcdpflsD] -uid N
  -used N -user NAME -xtype [bcdpfls]
```

Ta thấy

Lệnh find liệt kê sẵn cờ -executable để kiểm tra quyền thực thi. Đặc biệt ở phần -size N[bcwkMG], cái [bcwkMG] chính là danh sách các hậu tố đơn vị bao gồm b : for 512-byte

blocks (this is the default if no suffix is used) c : for bytes k : for Kilobytes bắt buộc phải có sau con số N. ta chỉ cần điền chữ c vào nghĩa là ta chọn hậu tố c (byte) là 1033c

Và cũng ở trong phần test

```
Tests (N can be +N or -N or N):
-amin N -anewer FILE -atime N -cmin N -cnewer FILE -context CONTEXT
-ctime N -empty -false -fstype TYPE -gid N -group NAME -ilname PATTERN
-iname PATTERN -inum N -iwholename PATTERN -iregex PATTERN
-links N -lname PATTERN -mmin N -mtime N -name PATTERN -newer FILE
-nouser -nogroup -path PATTERN -perm [-/]MODE -regex PATTERN
-readable -writable -executable
-wholename PATTERN -size N[bcwkMG] -true -type [bcdpflsD] -uid N
-used N -user NAME -xtype [bcdpfls]
```

ở đây em chỉ biết d là directory , f là file thường nên sẽ -type f

từ đó có lệnh find . -type f -size 1033c ! -executable

sau đó gõ lệnh và ta phát hiện được file hợp yêu cầu đang nằm ở maybehere07

sau dùng lệnh cat và trở vào file để xem pass

```
bandit5@bandit:~/inhere$ cat ./maybehere07/.file2
pXa26xhMWaC2SvDotA4r9EgZkul0eSBW
```

Bandit Level 6-7

```
bandit6@bandit:~$ ls
bandit6@bandit:~$ ls -a
.  ..  .bash_logout  .bashrc  .profile
bandit6@bandit:~$ ls -l
total 0
```

ở đây ko có thông tin file nào đáng kể

nên em sẽ dùng man bash tại mục Redirection

The standard output of `command1` is connected via a pipe to the standard input of `command2`. This connection is performed before any redirections specified by the `command1` (see REDIRECTION below). If `|&` is the pipeline operator, `command1`'s standard error, in addition to its standard output, is connected to `command2`'s standard input through the pipe; it is shorthand for `2>&1` |. This implicit redirection of the standard error to the standard output is performed after any redirections specified by `command1`.

sau tìm hiểu thì cụm `2>&1` này có nghĩa

Sau khi tìm hiểu thì cụm `2>&1` này có ý nghĩa như sau:

`2>` : Số 2 đại diện cho stderr (Standard Error - lỗi chuẩn). Ngoài ra tài liệu cũng ghi rõ: Toán tử `>` dùng để chuyển hướng. Do đó, ráp lại ta có `2>` nghĩa là: Chuyển hướng luồng lỗi chuẩn (stderr).

`&1` : Ký hiệu ám chỉ địa chỉ của stdout (Standard Output - đầu ra chuẩn). (Bắt buộc phải có dấu `&` đứng trước số 1, vì nếu gõ `2>1`, Linux sẽ tưởng mình muốn lưu báo lỗi stderr vào một file text có tên là "1").

Từ đó `2>&1` nghĩa là gộp chung luồng lỗi (stderr) vào cùng một chỗ với luồng kết quả đầu ra (stdout).

Sau đó qua mục man null

```
null(4)                                                    Kernel Interfaces Manual                                null(4)
NAME
    null, zero - data sink
DESCRIPTION
    Data written to the /dev/null and /dev/zero special files is discarded.
    Reads from /dev/null always return end of file (i.e., read(2) returns 0), whereas reads from /dev/zero always return bytes containing zero ('0' characters).
    These devices are typically created by:
        mknod -m 666 /dev/null c 1 3
        mknod -m 666 /dev/zero c 1 5
        chown root:root /dev/null /dev/zero
FILES
    /dev/null
    /dev/zero
NOTES
    If these devices are not writable and readable for all users, many programs will act strangely.
    Since Linux 2.6.31, reads from /dev/zero are interruptible by signals. (This change was made to help with bad latencies for large reads from /dev/zero.)
SEE ALSO
    chown(1), mknod(1), full(4)
Linux man-pages 6.17                                     2025-05-17                                         null(4)
Manual page null(4) line 1/29 (END) (press h for help or q to quit)
```

ở phần mục DESCRIPTION, tài liệu của hệ điều hành sẽ ghi rõ:

"Data written to the null or zero special file is discarded." (Dữ liệu ghi vào file đặc biệt null hoặc zero sẽ bị vớt bỏ/tiêu hủy).

Từ đó ta có `2>/dev/null` nghĩa là chuyển hướng luồng dữ liệu, không phải chuyển hướng file. Trong Linux có các luồng tiêu chuẩn gồm stdin (số 0), stdout (số 1), và stderr (luồng lỗi, số 2). Khi find quét hệ thống, nó sẽ gặp nhiều thư mục cấm truy cập và liên tục ném ra các thông báo "Permission denied" qua luồng stderr. Cú pháp `2>/dev/null` sẽ bắt toàn bộ luồng lỗi stderr này và ném vào thiết bị ảo `/dev/null`. Việc này giúp loại bỏ thông báo lỗi hiển thị trên terminal, chỉ giữ lại kết quả tìm kiếm đúng luồng stdout.

Dựa trên đề bài ta có

The password for the next level is stored **somewhere on the server** and has all of the following properties:

- owned by user bandit7
- owned by group bandit6
- 33 bytes in size

-user bandit7 : Lọc ra file thuộc quyền sở hữu của user bandit7.

-group bandit6 : Lọc ra file thuộc nhóm quyền bandit6.

-size 33c : Lọc ra file có kích thước chính xác là 33 bytes.

`2>/dev/null` : Ẩn đi các dòng thông báo lỗi.

`/` : Đây là thư mục gốc để trở lệnh find bắt đầu tìm kiếm trên toàn bộ hệ thống máy chủ.

Và từ đó ta có lệnh `find / -user bandit7 -group bandit6 -size 33c 2>/dev/null`

```
bandit6@bandit:~$ find / -user bandit7 -group bandit6 -size 33c 2>/dev/null  
/var/lib/dpkg/info/bandit7.password
```

sau dùng lệnh cat và trở vào file để xem pass

```
bandit6@bandit:~$ find / -user bandit7 -group bandit6 -size 33c 2>/dev/null  
/var/lib/dpkg/info/bandit7.password  
bandit6@bandit:~$ cat ./var/lib/dpkg/info/bandit7.password  
cat: ./var/lib/dpkg/info/bandit7.password: No such file or directory  
bandit6@bandit:~$ cat /var/lib/dpkg/info/bandit7.password  
Bmnnvf82KzQlfxgAI2d1zYbr1u9pr3E3  
bandit6@bandit:~$
```

Bandit Level 7-8

Theo như đề bài ở Level này thì password sẽ nằm trong file data.txt bên cạnh từ millionth

Bandit Level 7 → Level 8

Level Goal

The password for the next level is stored in the file **data.txt** next to the word **millionth**

Commands you may need to solve this level

man, grep, sort, uniq, strings, base64, tr, tar, gzip, bzip2, xxd

Cách giải quyết:

Sử dụng lệnh `ls -al` để xem toàn bộ thông tin file

```
bandit7@bandit:~$ ls
data.txt
bandit7@bandit:~$ ls -a
.  .. .bash_logout .bashrc .profile data.txt
bandit7@bandit:~$ ls -al
total 4108
drwxr-xr-x  2 root    root      4096 Jun 24 14:59 .
drwxr-xr-x 150 root    root      4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root       220 Feb 13  2026 .bash_logout
-rw-r--r--  1 root    root     3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root       807 Feb 13  2026 .profile
-rw-r----- 1 bandit8 bandit7 4184396 Jun 24 14:59 data.txt
bandit7@bandit:~$
```

ở đây em đề cập dãy số 4184396 nằm trước ngày tháng có nghĩa là file này có size nặng đến 4,2mb

do đó khi xem lệnh `cat` (`cat ./data.txt`) sẽ gây ra hiện tượng này

```
bandit7@bandit: ~  
Session Actions Edit View Help  
counterculture's gKyKEMdLkgdP0Cd3o8pf096F47YtHDL  
verse bM76NVCPUE768c1KhpwCv3zC0gztE3j  
underpay z21wtFeQnE3JwM52lPl9aGnsV1AFW3Vt  
indubitably 0Tf3yqtIwKPP187v65nqXSYnsquMX6v  
operations T7GvWuAC1z6XPMh5nuct1z6GnaJRu  
burliness TdbPmPUftMnKbNRCq70dua65ozhEND1E  
endlessness's 0Cr00V2CUMWN3npDQkYCG6anxompBd  
rankling PUZ4ccscextdDsf5Shu0dq9E2Xga82Z4  
Burton fjZmhRFcdyQOLPBqj06m1bnKwDwp  
terminates uIUqpXUxQ709295n38NogB1rGLn0AFcK  
Campinas's 08wLA831P2Z3F3cEGNBvY00hyC8eo0j  
spaded LpXztmEa2tV783dLlEmuch7ImedpRw  
aconites hLl0hwkeAN0Za7cXuxhLM3muK03Vsi  
Suwanee's iCUX8cMQNY3ST0dgXPG6WuUquV5nNhS  
coping's jOPYZnE9vUpQM4yaxJAuLnLuxzFvrRQs  
Aquariuses tWZghpBsFQwbKv3pIjQ7KffsrbPgP3v  
Grosz's 08gyJol5JnqqUpdw1Irh11E1bLVfZj  
pursues q2AC5ngpdcXVJ0Kof47Cx5nCoae8BzD  
investitures 7z1QC0QnzLgpdqK9JFQNo1UbhcbbFwv  
coffees rwj1bIv4tyKt8kmwE2md71AG5Uc0JAj  
lauded GvdlRfGtveEzCB8hu0YVf0KToFgsJ02  
lading EP8ePj8YQkn6311kbLne4EruulYwELK  
strawberries MVz14tdJPaMYbevX2CEU0IK0HTV4Nq1  
Kalamazoo's Zeee13P7F87Jk5zFXRoKiev6eHjLS4Q6  
koobaburra's EabpdeE2AgJLRxBvKckZ0M4bxfK2c3o  
noggins' 0YfAdVt5T5X1Lc211pTpB80v1Tp8Bv4A  
steadiness's WlnX59TCua0BNzsk5kZ1wg95bC2g9a0Mj  
marimba sDfQ2RUaEspvxy9yc15sz8RB0zDvtIQE  
seniors 1111sSMRpbpyd52Ac1mKk3z0hn7w7E3j  
plated 1s0Vx5GruV52p8Ypoy0Ne7Z0rkGVbJ  
frolicking bgtZjG5HYwpFFtVtHzUpQggxZ9MAG3hd  
confers srlDXg88sdqHz1aA5065Yg6w7Anyk1Bk  
dire XK235age70NS265Jp03gzv04U8Mhob  
nourishment's 3e1N1zn14e8JnHf056yDxP5SKWwQ1u8  
descender NDBPmG98tv55XQfcl6X8JkPbA4wYOAC  
Deadhead YhmU6FpVcFsg4vv71JnV1E9028nzJZA  
menstruation's d4lCdVC1CBmQ8PxyJ0papJYK53ABx  
inconsiderable c6qZTzYqL8Q9pU8AgtrbXtQvU4wLp6  
bellhop duEMyp56t9SP0bt0odiA8HEMMYih1u8M  
gaunt LX45rYgc0hjZEtVxRRYtmcPiOX1ieMR  
Halon's JRP2WSSv1OuHkOEK65bkaM1c01dCT3Q  
stochastic pRoSc5nHrFbAB8sHWC3jYVYQce7Hbx8  
Tuscaloosa NJRfBeUKSQ1Q0U85ZNS1je0Y7V1CBUC  
nearsighted AzskuRfQDBXTHrs9ua0vfkW60oVT  
Eichmann 9D92VokIFMT17ePwp4cNF6CKZGpu5Vv  
vinegary wclYp31Ql3k3K3vCMK8R0Mh1kEdusjd  
melancholic eKqzsk8hP05ReuljPYR19kawkLIILxTK  
bandit7@bandit:~$
```

Do đó vì file quá lớn, lệnh cat sẽ làm trôi mất dữ liệu, dựa đề bài đã gợi ý nên em sẽ dùng grep để lọc mục tiêu

Lệnh Grep có vai trò trong việc tìm kiếm và lọc văn bản

Lệnh **grep** trong hệ điều hành Linux được sử dụng để tìm kiếm các chuỗi ký tự hoặc mẫu văn bản theo yêu cầu. Cú pháp cơ bản là **grep [tùy chọn] [từ khóa] [tên file]**, cho phép bạn lọc dữ liệu một cách nhanh chóng

Cú pháp và cách sử dụng cơ bản

- Để tìm kiếm một từ trong một file: **grep "tu_khoa" ten_file.txt**
- Để không phân biệt chữ hoa và chữ thường: Thêm tùy chọn **-i** (ví dụ: **grep -i "tu_khoa" ten_file.txt**)
- Để tìm kiếm trong tất cả các file trong thư mục (đệ quy): Sử dụng **-r** (ví dụ: **grep -r "tu_khoa" /duong/dan/**)

Các tùy chọn phổ biến

- **-v**: Hiển thị các dòng không chứa từ khóa (đảo ngược kết quả)
- **-n**: Hiển thị số thứ tự của dòng khớp với kết quả
- **-c**: Đếm tổng số dòng có chứa từ khóa khớp trong file
- **-w**: Khớp đúng toàn bộ từ độc lập (không khớp nếu từ nằm trong từ khác lớn hơn)

và dựa trên đề bài đã gợi ý là từ millionth do vậy em có lệnh Grep “millionth” data.txt

```
bandit7@bandit:~$ Grep "millionth" data.txt
Command 'Grep' not found, did you mean:
  command 'mrep' from deb mblaze (1.1-1build1)
  command 'prep' from deb loki (2.4.7.4-12build1)
  command 'grep' from deb grep (3.12-1)
  command 'rep' from deb rep (0.92.7-4.1)
  command 'rrep' from deb rrep (1.3.7-1build1)
Try: apt install <deb name>
bandit7@bandit:~$ grep 'millionth' data.txt
millionth      VR1ljMayciFxbnUokuQmJFw6QC9VKtub
bandit7@bandit:~$
```

Lệnh lập tức quét qua file data.txt dung lượng 4.2MB và trích xuất thành công dòng chứa mật khẩu

Bandit Level 8-9

Đề bài ở Level này yêu cầu tìm dòng duy nhất xuất hiện đúng một lần trong file data.txt. File này chứa hàng vạn chuỗi ký tự ngẫu nhiên, đa số đều lặp đi lặp lại nhiều lần, chỉ có password là thứ duy nhất.

Bandit Level 8 → Level 9

Level Goal

The password for the next level is stored in the file **data.txt** and is the only line of text that occurs only once

Commands you may need to solve this level

grep, sort, uniq, strings, base64, tr, tar, gzip, bzip2, xxd

Helpful Reading Material

Piping and Redirection

Cách giải quyết

```
bandit8@bandit:~$ ls
data.txt
bandit8@bandit:~$ ls -al
total 56
drwxr-xr-x  2 root    root    4096 Jun 24 14:59 .
drwxr-xr-x 150 root    root    4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root     220 Feb 13  2026 .bash_logout
-rw-r--r--  1 root    root    3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root     807 Feb 13  2026 .profile
-rw-r----- 1 bandit9 bandit8 33033 Jun 24 14:59 data.txt
bandit8@bandit:~$
```

Bằng cách sử dụng lệnh `ls -al` thì em có 1 file có kích thước 3,3mb

Để lấy được mật khẩu ở Level 8, em phải tìm một chuỗi ký tự duy nhất không bị lặp lại trong file data.txt. Em đã sử dụng chuỗi lệnh `sort data.txt | uniq -u`.


```
bandit8@bandit:~$ sort data.txt | uniq -u.  
error: unexpected argument '-.' found  
  
tip: to pass '-.' as a value, use '-- -.'  
  
Usage: uniq [OPTION]... [INPUT [OUTPUT]]  
  
For more information, try '--help'.  
bandit8@bandit:~$ sort data.txt | uniq -u  
EjmOSvuAu7sGAHqHVcBDPirRe9T03kx1  
bandit8@bandit:~$
```

Lệnh sort thường dùng để sắp xếp toàn bộ văn bản. Việc sắp xếp này có tác dụng gom tất cả các data giống nhau về đứng liền kề nhau.

Lệnh uniq thường có nhiệm vụ phát hiện và xử lý trùng lặp. Tuy nhiên, nó bị giới hạn là chỉ nhận diện được sự trùng lặp của các dòng nằm sát cạnh nhau vừa được sort gom lại ở bước trên cho nên em sử dụng dấu | để chuyển hướng stdout của lệnh sort trực tiếp làm stdin cho lệnh uniq.

Phần -u

Thay vì gộp các dòng lặp lại như mặc định, tham số -u sẽ loại bỏ hoàn toàn mọi dữ liệu có sự trùng lặp, chỉ xuất ra màn hình dòng duy nhất thỏa mãn yêu cầu của bài, đó chính là mật khẩu.

```
bandit8@bandit:~$ sort data.txt | uniq -u  
EjmOSvuAu7sGAHqHVcBDPirRe9T03kx1  
bandit8@bandit:~$
```

Bandit Level 9-10

Mật khẩu cho Level 10 được cất giấu trong file data.txt. File này chứa rất nhiều dữ liệu nhị phân không thể đọc được. Mật khẩu là một chuỗi văn bản thông thường (human-readable) và có đặc điểm nhận dạng là nằm ngay sau một vài ký tự dấu bằng (=).

Bandit Level 9 → Level 10

Level Goal

The password for the next level is stored in the file **data.txt** in one of the few human-readable strings, preceded by several '=' characters.

Commands you may need to solve this level

grep, sort, uniq, strings, base64, tr, tar, gzip, bzip2, xxd

Dùng ls -al để kiểm tra toàn bộ thông tin file ở level này

```
bandit9@bandit:~$ ls
data.txt
bandit9@bandit:~$ ls -al
total 40
drwxr-xr-x  2 root    root    4096 Jun 24 14:58 .
drwxr-xr-x 150 root    root    4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root     220 Feb 13 2026 .bash_logout
-rw-r--r--  1 root    root   3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root    807 Feb 13 2026 .profile
-rw-r----- 1 bandit10 bandit9 19382 Jun 24 14:58 data.txt
bandit9@bandit:~$
```

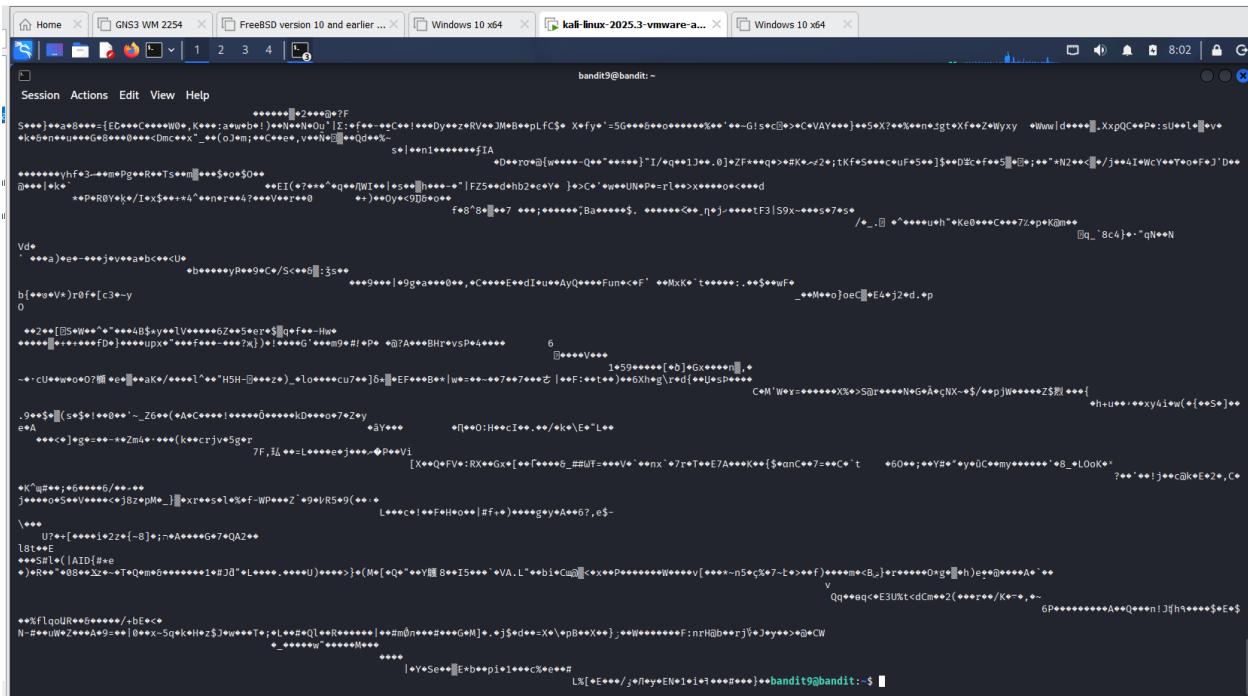
.profile : File này tự động chạy một lần duy nhất ngay khi em vừa gõ mật khẩu đăng nhập thành công vào hệ thống (thông qua SSH). Nó thường dùng để thiết lập các biến (như cài đặt đường dẫn \$PATH).

.bashrc: Nó dùng để tinh chỉnh trải nghiệm cá nhân và tự động chạy mỗi khi em mở cửa sổ terminal mới, ví dụ: tô màu chữ, tạo các lệnh viết tắt (alias), hoặc thay đổi định dạng con trỏ chuột nhấp nháy.

.bash_logout : Ngược lại với hai file trên, file này chỉ chạy khi em đăng xuất khỏi hệ thống. Nó thường chứa các lệnh dọn dẹp như xóa file rác tạm thời, xóa lịch sử lệnh vừa gõ, hoặc in ra một dòng chữ tạm biệt.

Và file data.txt có kích thước khoảng 19mb vì kích thước nó nặng cho nên em không thể dùng lệnh cat data.txt

Nếu em sử dụng lệnh cat data.txt thì chỉ in ra dữ liệu nhị phân màn hình



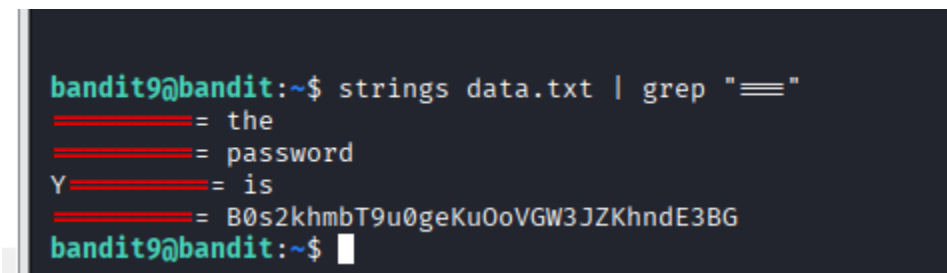
Và dựa trên danh sách các lệnh mà đề bài đưa ra (grep, sort, uniq, strings, base64, tr, emr, gzip, bzip2, xxd)

Em sử dụng lệnh strings và grep cụ thể là lệnh `strings data.txt | grep "==="`

Lệnh Strings có thể quét toàn bộ một file (ngay cả file không phải là văn bản thuần túy) và chỉ in ra màn hình các chuỗi ký tự mà con người có thể đọc được (thường là từ 4 ký tự trở lên). Nó giúp gạt bỏ toàn bộ dữ liệu rác trong data.txt.

Còn Lệnh Grep dùng để tìm kiếm ở đây, grep sẽ nhận kết quả văn bản sạch từ lệnh strings và lọc ra những dòng có chứa chuỗi dấu `===` để tìm ra mật khẩu.

Dấu `|` sẽ chuyển luồng lệnh Strings từ stdout thành từ stdin và đưa cho Grep kiểm tra và tìm kiếm và chuyển lại thành stdout từ đó em có thể lấy được mật khẩu.



Bandit Level 10-11

Ở đây mật khẩu được giấu trong file data.txt. Lần này nội dung file không còn bị lẫn dữ liệu rác hay nhị phân nữa, nhưng nó đã bị biến đổi hình dạng bằng thuật toán Base64.

Bandit Level 10 → Level 11

Level Goal

The password for the next level is stored in the file **data.txt**, which contains base64 encoded data

Commands you may need to solve this level

grep, sort, uniq, strings, base64, tr, tar, gzip, bzip2, xxd

Helpful Reading Material

[Base64 on Wikipedia](#)

Ở Level này, kích thước file tụt xuống chỉ còn 69 bytes.

```
bandit10@bandit:~$ ls -al
total 24
drwxr-xr-x  2 root    root    4096 Jun 24 14:58 .
drwxr-xr-x 150 root    root    4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root     220 Feb 13  2026 .bash_logout
-rw-r--r--  1 root    root    3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root     207 Feb 13  2026 .profile
-rw-r----- 1 bandit11 bandit10  69 Jun 24 14:58 data.txt
bandit10@bandit:~$
```

Khi xem bằng lệnh cat data.txt thì ở đây các ký tự lộn xộn xuất hiện ở màn hình chính là mật khẩu, nhưng nó đang ở dạng đã bị mã hóa bằng thuật toán Base64.

```
bandit10@bandit:~$ cat data.txt
VGhlIHBhc3N3b3JkIGlzIHBZZk9ZNkh3VXNEajVyTDlvbnloVTdNQ212OHZONVJvCg==
bandit10@bandit:~$
```

Và dựa trên đề bài gợi ý base64 thì ở đây thuật toán sử dụng 64 ký tự khác nhau trong bảng mã ASCII để biểu diễn dữ liệu nhị phân. Cụ thể, các ký tự này bao gồm:

26 chữ cái in hoa: A-Z

26 chữ cái thường: a-z

10 chữ số: 0-9

Hai ký tự đặc biệt: + và /

Do đó em sử dụng lệnh `cat data.txt | base64`

```
bandit10@bandit:~$ cat data.txt | base64
VkdobElIQmhjM04zYjNKa0LHbHpJSEJaWms5Wk5raDNWWE5FYWpWeVREbFZkbmxxvLkTLEyMTJP
SFpPTLZKdkNnPT0K
bandit10@bandit:~$
```

Nhưng Lệnh (`cat data.txt | base64`), thay vì giải mã, kết quả lại trả về một chuỗi ký tự dài hơn. Nguyên nhân là do khi đứng một mình, lệnh `base64` sẽ mặc định thực hiện chức năng Mã hóa. Do đó, file dữ liệu đã bị hệ thống mã hóa chồng thêm lớp thứ 2

Chính vì vậy ta phải bắt buộc phải thêm tham số `-d` là Decode để chỉ định hệ thống thực hiện quá trình Giải mã để đảo ngược quá trình và trả về mật khẩu gốc.

```
bandit10@bandit:~$ cat data.txt | base64 -d
The password is pYfOY6HwUsDj5rL9UvyhU7MCmv8vN5Ro
bandit10@bandit:~$
```

Bandit Level 11-12

Mật khẩu trong file data.txt lần này được bảo vệ bằng một kỹ thuật mật mã học cổ điển mang tên ROT13. Tất cả các chữ cái trong file đã bị dịch chuyển 13 vị trí trong bảng chữ cái. Các ký tự số hay dấu câu vẫn được giữ nguyên.

Bandit Level 11 → Level 12

Level Goal

The password for the next level is stored in the file **data.txt**, where all lowercase (a-z) and uppercase (A-Z) letters have been rotated by 13 positions

Commands you may need to solve this level

grep, sort, uniq, strings, base64, tr, tar, gzip, bzip2, xxd

Helpful Reading Material

[Rot13 on Wikipedia](#)

Thì ROT13 là một mật mã thay thế chữ cái đơn giản thay thế một chữ cái bằng chữ cái thứ 13 sau nó trong bảng chữ cái và các ký tự không phải là chữ cái (số, dấu chấm, dấu phẩy) thì giữ nguyên.. Ví dụ A dịch chuyển 13 bước sẽ thành N và G dịch chuyển 13 bước sẽ thành T

Cách giải quyết:

Dùng lệnh `ls -a` để xem file để xem danh sách các file trong thư mục hiện tại

```
bandit11@bandit:~$ ls -a
.  ..  .bash_logout .bashrc .profile data.txt
bandit11@bandit:~$
```

```
bandit11@bandit:~$ ls -al
total 24
drwxr-xr-x  2 root    root    4096 Jun 24 14:58 .
drwxr-xr-x 150 root    root    4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root     220 Feb 13  2026 .bash_logout
-rw-r--r--  1 root    root   3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root     807 Feb 13  2026 .profile
-rw-r--r--  1 bandit12 bandit11   49 Jun 24 14:58 data.txt
bandit11@bandit:~$
```

Tiếp theo, để xem thông tin chi tiết, em dùng lệnh `ls -al`. Kết quả trả về cho thấy có 3 file script ẩn (.bash_logout, .bashrc, .profile) dùng để cấu hình giao diện dòng lệnh Bash. Quan trọng nhất là file data.txt. File này được tạo ra bởi user bandit12, nhưng

quyền tương tác lại được cấp cho nhóm bandit11 (chính là tài khoản em đang dùng). File có kích thước rất nhỏ, chỉ 49 bytes.

```
bandit11@bandit:~$ cat data.txt
Gur cnffjbeq vf TEBbmJCB8DlA0zTewHxVQ0JPLxMvDkeA
bandit11@bandit:~$
```

Khi sử dụng lệnh `cat data.txt`, em nhận thấy thông tin bên trong file không thể đọc hiểu trực tiếp mà đã bị mã hóa thành một chuỗi ký tự lạ do đó, để giải mã, em cần áp dụng quy luật vòng lặp của ROT13: vì bảng chữ cái có 26 ký tự, việc tiếp tục dịch chuyển chuỗi bị mã hóa thêm 13 vị trí nữa sẽ đưa nó quay về đúng trạng thái gốc ban đầu.

em kết hợp | và lệnh `tr`

`cat data.txt | tr 'a-zA-Z' 'n-Za-mN-ZA-M'`

'a-zA-Z' là tập hợp đầu vào, đại diện cho toàn bộ các chữ cái (viết thường và viết hoa) mà hệ thống cần tìm kiếm và 'n-Za-mN-ZA-M' là tập hợp thay thế đã được tịnh tiến 13 vị trí. Cụ thể, các chữ cái từ a đến m sẽ bị biến thành n đến z, và ngược lại từ n đến z sẽ quay vòng lại thành a đến m kể cả các chữ cái in hoa

```
Gur cnffjbeq vf TEBbmJCB8DlA0zTewHxVQ0JPLxMvDkeA
bandit11@bandit:~$ cat data.txt | tr 'a-zA-Z' 'n-Za-mN-ZA-M'
The password is GROozWPO8QyN0mGrjUkID0WCYkZiQxrN
bandit11@bandit:~$
```

Sau khi nhập lệnh `cat data.txt | tr 'a-zA-Z' 'n-Za-mN-ZA-M'` thì em thấy dãy ký tự mã hóa đã giải mã thành câu:

The password is GROozWPO8QyN0mGrjUkID0WCYkZiQxrN

Từ đó em lấy mật khẩu và đăng nhập lên level tiếp theo


```
(kali㉿kali)-[~]  
$ ssh bandit12@bandit.labs.overthewire.org -p 2220
```

OverTheWire

This is an OverTheWire game server.
More information on <http://www.overthewire.org/wargames>

backend: gibson-1
bandit12@bandit.labs.overthewire.org's password:

OverTheWire

www. ver he " ire.org

Welcome to OverTheWire!

Level 12-13

[Donate!](#) [Help!](#)

Bandit Level 12 → Level 13

Level Goal

The password for the next level is stored in the file **data.txt**, which is a hexdump of a file that has been repeatedly compressed. For this level it may be useful to create a directory under `/tmp` in which you can work. Use `mkdir` with a hard to guess directory name. Or better, use the command `"mktemp -d"`. Then copy the datafile using `cp`, and rename it using `mv` (read the manpages!)

Commands you may need to solve this level

`grep`, `sort`, `uniq`, `strings`, `base64`, `tr`, `tar`, `gzip`, `bzip2`, `xxd`, `mkdir`, `cp`, `mv`, `file`

Helpful Reading Material

[Hex dump on Wikipedia](#)

Mật khẩu tiếp tục được giấu trong file `data.txt`. Tuy nhiên, file này đang là một bản hexdump

```
bandit12@bandit:~$ ls -al
total 24
drwxr-xr-x  2 root   root   4096 Jun 24 14:58 .
drwxr-xr-x 150 root   root   4096 Jun 24 15:02 ..
-rw-r--r--  1 root   root    220 Feb 13 2026 .bash_logout
-rw-r--r--  1 root   root  3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root   root    807 Feb 13 2026 .profile
-rw-r----- 1 bandit13 bandit12 2641 Jun 24 14:58 data.txt
bandit12@bandit:~$ cat data.txt
00000000: 1f8b 0808 a6f0 3b6a 0203 6461 7461 322e .....;j..data2.
00000010: 6269 6e00 0144 02bb fd42 5a68 3931 4159 bin..D...BZh91AY
00000020: 2653 5904 ab91 e100 001c 7fff fffb bebf 6SY.....
00000030: f1fb dfbb be7f f57d fef5 5f8f ffcd b7b6 .....}.._.....
00000040: 19ff f6df af7f feae fff6 7fff 3001 3b6d .....0.;m
00000050: 5b10 0000 001a 341a 34f5 000d 0068 0000 [....4.4....h..
00000060: 0000 0683 2068 1ea0 3400 0d1e a034 19a8 ...h..4....4..
00000070: 0680 3d4d 00d0 69ea 69a6 0f54 41a0 00d1 ..=M...i.i...TA...
00000080: a034 d0c8 f506 8c86 8068 1a32 01a0 c40c .4.....h.2....
00000090: 8323 40c8 0681 8803 4d32 1a34 0320 0000 .#@.....M2.4. ...
000000a0: 0d19 00d0 1a7a 834d 0ca6 8343 4000 00d1 .....z.M...C@...
000000b0: a006 87a8 0064 0003 41ea 321a 0321 91ea .....d..A.2...!..
000000c0: 001a 3403 4686 81ea 0069 a680 0d3d 434d ..4.F...i...=CM
000000d0: 0003 201e a687 21c0 488e 0290 095a 3e86 .. ...!.H....Z>.
000000e0: 15f5 36e7 cde1 c0a6 6618 63cd b8f0 63ef ..6.....f.c...c.
000000f0: c79a d24a 84c8 a6ce 178f cb25 70ec 85a8 ...J.....%p...
00000100: ca3e a695 c48f 63d0 116e 8bb2 4c01 11ee .>....c..n...L...
00000110: e859 c127 9c43 5d46 adcd f083 1fd6 9c89 .Y..'.C]F.....
00000120: f4cd 2dc8 4c94 133b 9845 6506 39e4 066c ..-.L...;.Ee.9..l
00000130: e84b 7292 86b9 83cb 4cc5 06b6 bbc2 0be3 .Kr....L.....
00000140: 45f7 d0a2 f33d 5e21 e3ae 5636 d65c f20a E....=^!..V6.\..
00000150: dd0a 527e 1bd2 d0c4 07d4 2905 cdc2 214d ..R~.....) ...!M
00000160: cd24 464b 1b79 2165 218b a0e2 0c9c f1d3 .$FK.yte!.....
00000170: 823d 6c2a 4acb 6c50 d11b a702 d33a 28c5 .=l*J.LP.....:(.
00000180: 2df2 7d4f b3c4 3d41 1268 0e84 6280 1f1d -.}G...=A.h...b...
00000190: a361 7bf7 1841 d56e 18e7 c416 fe1a 4a94 .a{..A.n.....J.
000001a0: 6978 74a7 0b53 a10b 1fec 8221 bb20 871a ixt..S.....!. ..
000001b0: 8f98 b993 459e 8e21 ca67 26bf f599 67e2 ....E...!.g6...g.
000001c0: b74b 17ac ac63 0172 3ca0 005f e6e0 ca84 .K...c.r<..._....
000001d0: bcba 40aa aca8 0565 c111 1570 9e84 1127 ..@.....e...p...
000001e0: 8426 1a74 ca3c cf43 6100 7865 4a10 e1d7 .6.t.<.Ca.xeJ...
000001f0: 6d32 fd7e 8947 ec20 093b d503 ccf4 833c m2.~.G. .;....<
00000200: b6c7 1583 b688 4610 e191 244f e412 9ced .....F...$0....
00000210: 27a7 71ac 6a6b ba1d 54e8 be4e 8fe1 744f '.q.jk..T..N...t0
00000220: b562 b142 33e9 fd09 194b 09de 54de 2de2 .b.B3...K..T.-.
00000230: 0934 7a39 638a 9941 4fe0 ea53 1103 4007 .4z9c..A0..S..@.
00000240: 52ea d2d6 00c3 6d4b c97a 2006 242f 4bb1 R....mK.z .$/K.
```

Dựa vào gợi ý em sẽ dùng “mktemp -d” để tự động tạo một thư mục mới trong vùng nhớ tạm /tmp với một cái tên ngẫu nhiên

```
drifter.labs.overthewire.org formulaone.labs.overthewire.org ip6-mcastpref1
bandit12@bandit:~$ mktemp -d
/tmp/tmp.oWZIOwBrsm
bandit12@bandit:~$
```

Sau đó dùng lệnh Cd để di chuyển thư mục

```
bandit12@bandit:~$ cd /tmp/tmp.oWZIOwBrsm
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Rồi copy file data.txt

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ cp ~/data.txt .
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Dấu ngã ~ ở đây đại diện cho thư mục của tài khoản bandit12. Nó chỉ định hệ thống đi tìm file data.txt ở đúng nơi chứa nó.

Ở đây em dùng lệnh xxd -r data.txt > data2 để dịch ngược hexdump

xxd: Công cụ xử lý hexdump.

-r (reverse): Thay vì biến file thành mã thập lục phân, nó sẽ đọc mã thập lục phân trong data.txt và khôi phục nó về dạng file gốc.

> data2: điều hướng kết quả nhị phân vừa được khôi phục lưu vào một file mới tinh mang tên data2, giúp chúng ta giữ nguyên vẹn file data.txt ban đầu để đề phòng sai sót.

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ xxd -r data.txt > data2
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data2
data2: gzip compressed data, was "data2.bin", last modified: Wed Jun 24 14:58:46 2026, max compression, from Unix, original size modulo 2^32 580
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Ngay sau khi lệnh trên chạy xong, em gõ tiếp lệnh file data2 để xem cấu trúc file mới

data2: gzip compressed data là thuật toán nén gzip.

Em dùng tiếp lệnh di chuyển/đổi tên mv và gắn thêm đuôi .gz vào sau data2

mv data2 data2.gz

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data2 data2.gz
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Dùng lệnh gzip tham số -d để giải mã nó ra

gzip -d data2.gz

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ gzip -d data2.gz
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Và dùng lại lệnh file data2 để xem lại cấu trúc file

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data2
data2: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Sau khi xem lại cấu trúc file thì lần này hệ thống sử dụng thuật toán nén bzip2

Vì thế em tiếp tục lệnh mv và gắn thêm thêm .bz2 vào

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data2 data2.bz2
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Tiếp tục dùng tham số -d để giải mã file

bzip2 -d data2.bz2

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ bzip2 -d data2.bz2
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Và dùng lại lệnh file data2 để xem cấu trúc file

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data2
data2: gzip compressed data, was "data4.bin", last modified: Wed Jun 24 14:58:46 2026, max compression, from Unix, original size modulo 2^32 20480
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Ở lần này file lại dùng tiếp thuật toán gzip nên là em dùng lại các lệnh như trên và dùng lệnh file data2 để dùng lại cấu trúc file

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data2 data2.gz
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ gzip -d data2.gz
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data2
data2: POSIX tar archive (GNU)
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Ở lần này em thấy file đã nén lại thành file.tar

Do đó em sẽ tiếp tục dùng lệnh mv và gắn đuôi tar vào

mv data2 data2.tar

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data2 data2.tar
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Thay vì dùng -d như phần trên, với tar, em sẽ dùng -x để giải nén và -f tar -xf data2.tar

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ tar -xf data2.tar
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Sau đó em dùng lệnh ls -al để xem thông tin file

Và ở đây em có file mới tên là file data5.bin

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ ls -al
total 36
drwx----- 2 bandit12 bandit12 100 Aug 21 13:06 .
drwxrwx-wt 91 root      root      2360 Aug 21 13:07 ..
-rw-r----- 1 bandit12 bandit12 2641 Aug 21 12:44 data.txt
-rw-rw-r-- 1 bandit12 bandit12 20480 Aug 21 12:49 data2.tar
-rw-r--r-- 1 bandit12 bandit12 10240 Jun 24 14:58 data5.bin
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Em dùng file data5.bin để xem cấu trúc file

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data5.bin
data5.bin: POSIX tar archive (GNU)
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Và em tiếp tục dùng các lệnh như trên và có được file data6

```
data5.bin: POSIX tar archive (GNU)
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data5.bin data5.tar
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ tar -xf data5.tar
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ ls -al
total 40
drwx----- 2 bandit12 bandit12 120 Aug 21 13:10 .
drwxrwx-wt 92 root      root      2400 Aug 21 13:10 ..
-rw-r----- 1 bandit12 bandit12 2641 Aug 21 12:44 data.txt
-rw-rw-r-- 1 bandit12 bandit12 20480 Aug 21 12:49 data2.tar
-rw-r--r-- 1 bandit12 bandit12 10240 Jun 24 14:58 data5.tar
-rw-r--r-- 1 bandit12 bandit12 223 Jun 24 14:58 data6.bin
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

```
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data6.bin data6.bz2
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ bzip2 -d data6.bz2
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data6
data6: POSIX tar archive (GNU)
```

Tiếp tục dùng lệnh tương tự như thế cho đến file data8.bin

```
mv: cannot stat 'data8.bin': No such file or directory
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data6 data6.tar
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ tar -xf data6.tar
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ ls -al
total 52
drwx----- 2 bandit12 bandit12 140 Aug 21 13:13 .
drwxrwx-wt 93 root      root    2400 Aug 21 13:13 ..
-rw-r----- 1 bandit12 bandit12 2641 Aug 21 12:44 data.txt
-rw-rw-r-- 1 bandit12 bandit12 20480 Aug 21 12:49 data2.tar
-rw-r--r-- 1 bandit12 bandit12 10240 Jun 24 14:58 data5.tar
-rw-r--r-- 1 bandit12 bandit12 10240 Jun 24 14:58 data6.tar
-rw-r--r-- 1 bandit12 bandit12 79 Jun 24 14:58 data8.bin
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ file data8.bin
data8.bin: gzip compressed data, was "data9.bin", last modified: Wed Jun 24 14:58:46 2026, max compression, from Unix, original size modulo 2^32 49
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Và dùng các lệnh tương tự như đối với file data8.bin sau đó em dùng lệnh cat data8 và có được password để lên level tiếp theo

```
data8.bin: gzip compressed data, was "data9.bin", last modified: Wed Jun 24 14:58:46 2026, max compression, from Unix, original size modulo 2^32 49
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ mv data8.bin data8.gz
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ gzip -d data8.gz
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$ cat data8
The password is qQYQiHOBPR8zR61qxYqX45quvihF2uzk
bandit12@bandit:/tmp/tmp.oWZIOwBrsm$
```

Bandit Level 13-14

[Donate!](#) [Help!?](#)

Bandit Level 13 → Level 14

Level Goal

The password for the next level is stored in `/etc/bandit_pass/bandit14` and can only be read by user `bandit14`. For this level, you don't get the next password, but you get a private SSH key that can be used to log into the next level. Look at the commands that logged you into previous bandit levels, and find out how to use the key for this level. If you need help with this level: a hint file can be found in the home directory. Make sure to read the error messages as they are informative.

Commands you may need to solve this level

ssh, scp, umask, chmod, cat, nc, install

Helpful Reading Material

[SSH/OpenSSH/Keys](#)
[Transferring Files via SCP](#)

Lần này Mục tiêu: Lấy mật khẩu của Level 14 đang được giấu tại đường dẫn `/etc/bandit_pass/bandit14`.

Trở ngại: File này được phân quyền rất chặt, chỉ duy nhất tài khoản `bandit14` mới có quyền đọc nó. Ở vị trí hiện tại (là user `bandit13`), bạn không thể dùng lệnh `cat` thẳng vào file đó được vì sẽ bị báo lỗi "Permission denied".

hệ thống để sẵn trong thư mục home một chiếc Private SSH Key (Khóa bảo mật cá nhân).

Bản chất của Level này sử dụng cơ chế xác thực bằng SSH Key thay cho mật khẩu truyền thống. Phương pháp này dùng Mật mã bất đối xứng (Asymmetric Cryptography) gồm Public Key (Khóa công khai đặt trên Server) và Private Key (file `sshkey.private` mà em kéo về máy bằng lệnh `scp`). Khi kết nối, Server tạo ra một thông điệp ngẫu nhiên, em dùng Private Key để mã hóa câu trả lời, và Server dùng Public Key tương ứng để giải mã và xác thực.

Cách làm

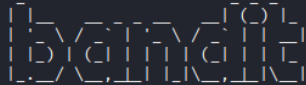
Đầu em dùng lệnh `ls -al` để tìm tên chính xác của chiếc chìa khóa

```
bandit13@bandit:~$ ls -al
total 28
drwxr-xr-x  2 root    root    4096 Jun 24 14:58 .
drwxr-xr-x 150 root    root    4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root     220 Feb 13  2026 .bash_logout
-rw-r--r--  1 root    root   3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root    807 Feb 13  2026 .profile
-rw-r-----  1 bandit14 bandit13  467 Jun 24 14:58 .HINT
-rw-r-----  1 bandit14 bandit13 2602 Jun 24 14:58 sshkey.private
bandit13@bandit:~$
```

File này hiển thị thông số phân quyền là -rw-r-----. Mặc dù chủ sở hữu tạo ra nó là bandit14, nhưng quyền tương tác lại được chia sẻ cho nhóm bandit13. Vì em đang đóng vai user bandit13, em được cấp quyền r

Và em thử kết nối trực tiếp từ bandit13 và kết nối không được

```
bandit13@bandit:~$ ssh -i sshkey.private bandit14@bandit.labs.overthewire.org -p 2220
The authenticity of host '[bandit.labs.overthewire.org]:2220 ([127.0.0.1]:2220)' can't be established.
ED25519 key fingerprint is: SHA256:C2ihUBV7ihnV1wUXRb4RrEcLfXC5CXlhmAAM/urerLY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/home/bandit13/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/home/bandit13/.ssh/known_hosts).
```

The logo for OverTheWire, featuring the words "OverTheWire" in a stylized, blocky font where the letters are interconnected.

This is an OverTheWire game server.
More information on <http://www.overthewire.org/wargames>

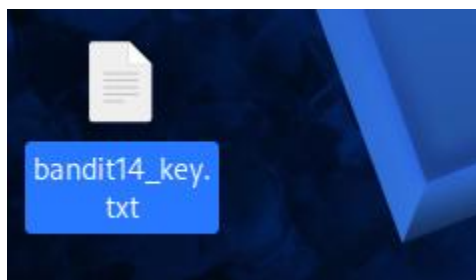
```
!!! You are trying to log into this SSH server with a password on port 2220 from localhost.
!!! Connecting from localhost is blocked to conserve resources.
!!! Please log out and log in again.
```

```
backend: gibbon-1
Received disconnect from 127.0.0.1 port 2220:2: no authentication methods enabled
Disconnected from 127.0.0.1 port 2220
bandit13@bandit:~$
```

Dùng lệnh cat sshkey.private


```
bandit13@bandit:~$ cat sshkey.private
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAuCCoxSR6xDCnsm98kqan1x1JF3mfZ6kZa+BoAHetQ/91F4EKTfmE
E+Xs8yVgLhn1YL0TvyVswMzy330eFJV/KEzef54V8yZo7jFcx+pQl0F6+BFRy+wsyLASV5
XxD/AtafdbVfLZFGTLC53k0FFt0VxokFmnTLIwRyxRJUNAWP9+fkAtbnfqkxiWqg0ZaLr
1fICYam6vb6ilmNfuiGHZyQNHetK0KZgAaMnQW6bYlRjnkxsNNxk1pj0sT3MUQdLrPCdyh
l8rXUqZ60NZPA6X82/hJNQJR+zVghXrGmTTLU7MAHN7rTdoq4bIQtdShuZZmd5igp50vVg
tCn4bRM2CFXl8m0P6gNDpR+VYH5f99MwdXyrDUAzuusH7H6CyawRZZF8rF0q0Nc6HwTJ2h
YJw2uf85ltd3wR8XWzvnBlf2+U90Emhs01uEYNTNvhq7Gvz/TGI0wR0hEBmsznSns0jShT
cqVsnTMhHaXse3u2D+tbGoC3w0C0yjeX7Skhq63bAAAFiMnVC+zJ1QvsAAAAB3NzaC1yc2
EAAAGBALgggMUKesQwp7JvfJKmp9cdSRd5n2epGWgaAB3rUP/dReBCK35hBPL7PMLVC4Z
9WC9E78lbMDM8t9znhsVfyhM3n+eFfMma04xMfqUJThevgRUcvsLMiwEleV8Q/wLWn3W1
Xy2RRkywud5DhX09FcaJBzP05SMEcsUSbjQFj/fn5ALW536pJIsVqoNGWi69XyAmGpur2+
opZjX7ohh2ckDR3k5DimYAGjJ0Fum2JUy55MbdTcZNaY9LE9zFEHS6zwncoZfK11KmetDW
Tw0l/Nv4STUCUfs1YV6xpk05V0zABze603aKuGyELQ0obmWZneYoKeTr1YLQp+G0TNghV
5fJtd+oDQ6jUfLWB+x/fTMHV8qw1AM7rrB+x+gsmsEWWRFKxaKjjX0h8EydoWCCNrn/OZbQ
98EFf1s75wZX9vLpThJobNNbhGDbTb4auxr8/0xiNMEdIRAZrM50p7NI0uU3KlbJ0zIR2l
7Ht7tg/rWxqAt8DnDso3l+0pIaut2wAAAAMBAAEAAAGAEgTUL1LGftwCFUK2yK05gKIzjH
IRCPZx7+4qj10m3iAqR84PgZj49W+LVDIkqu5MzpaqT4rsjs0hYv+wCSimJH39SjTgxgZM
v36iK0hBcYhtXchoHLIzAcLFUL/yMtKYxyV3UT5uQwIoIq9lbaQerP7jlrjHWDfP2y85k9
oqams6aEWEjKp8kKs/e/U5B3c9qBbCZ+dRyI7W32vDKvZsB0puZC4JrYeOnqpmRY968lD6
3Lty3WtyDNQ0IgI/s/BIK4wmzFM/drZHOIJYjzJssyvjaSf5XydPq0sK+z/0wRUt1ev4+j
2hBuFqunZN0uq2nIz4LSSocLPtTZqu2PhbQgGjJ80aXSH+TkKoLv+sG8d0+rrWtllkDJPX
YsWBmcWfd/rJ0LnkOBSGu+00ne4IpK+7wAWNoJwpw8MQkLRJkAtay0rsGw3Bt7Bf7oqnDA
gPFNfgckMfhWi0Rhwzgm5zEK50g4cCgwdCH2YQwQlRQHWWKkPat9XjXCxsj3N9D1BAAAA
wF2LTVT5VAvkqhJRe4KeT8RhydARmWdt/6YUY+liDnK/Bm4lhpeUrXJ2frX1sGeAty60ZL
LA31Y+kV9xgS4HN0T2aRTCXdfVJ4XmMCs1TxcRejTo92c3EIfD/ttbxkoLTsR/2tjkyje3
GbMOZpg3n0Rgtph0sJYfY5XyBBYNEg7GEJ6jSNBr9nA+wZILqVbuaDdn+FeVcgWSxFUyIC
kGZ0HketuIdv7EkperlJCcklOLl6Z3i0jwlfCmuZj98b1u/QAAAMEA5JNGvpj8WT4aQuM7
XME/N/m//8/sAb2DMHUWMY0ySSSNRDbM3pJkKja7nUp0CybwTYTrf/agLxIgdQAo71GpK7
ePRmsGu5+mrreNJKicGyER0IqCBhbWyljGDKFMJNGb2gk0Mu9XNZk9y3lRDmPRcfBMekmV
fAjvy5rgAqyf/PsKznyZE12eGosH+CkfVWXDVRXd/hoOdWIZqAC+w8nLso6WLKhptWz8ke
SghZBBAsJW42cyenvyIdIzpVICJpubAAAawQD00Coj/QwJLwX0d75KuUsfgI0Esq9vLSWL
Ds3fQghnNMEJZfD9B/W8Xa7VClfPHDItcDoXiSgj4dQnS1JeeVBBUHLULmKLMNLRNQjLD
0HSgyFYTPxl8t05ZALFRnGEwe7y9RvNeXp9zPQC2v1FTVQ2RdALiWvR4fGyDu0ER4hYiA/
WfqaBSBABkdhyltBja/VncIHBZ04Bk1S9nwc0z6USyTXpTwpZIJw1074Tjk+8X3or8WC
KN158egnSb+sEAAA0cnVkeUBsb2NhbGhvc3QBAgMEBQ==
-----END OPENSSH PRIVATE KEY-----
bandit13@bandit:~$
```

Sau đó copy toàn bộ vào file khác và đặt tên là bandit14_key



Rồi dùng lệnh `ssh -i bandit14_key.txt bandit14@bandit.labs.overthewire.org -p 2220` để đăng nhập vào level tiếp theo

Tuy nhiên em vẫn gặp phải lỗi như vậy

bandit14_scp_key.txt: Tên file mục tiêu đang được nhắm tới.

Dùng lệnh `ls -l bandit14_scp_key.txt` xem file đã nằm gọn trên máy với quyền `-rw-----` chưa

```
(kali@kali)-[~]
$ ls -l bandit14_scp_key.txt
-rw----- 1 kali kali 2602 Aug 21 12:02 bandit14_scp_key.txt
```

Đăng nhập bằng Private Key với lệnh

```
ssh -i bandit14_key.txt -o PubkeyAcceptedKeyTypes=+ssh-rsa
bandit14@bandit.labs.overthewire.org -p 2220
```

`-i bandit14_key.txt`: Chỉ định tệp khóa bí mật dùng để xác thực thay thế cho mật khẩu.

Và em cũng kèm tham số `-o PubkeyAcceptedKeyTypes=+ssh-rsa` vào lệnh tránh tình trạng bị lỗi như trên

```
(kali@kali)-[~]
$ ssh -i bandit14_key.txt -o PubkeyAcceptedKeyTypes=+ssh-rsa bandit14@bandit.labs.overthewire.org -p 2220

bandit14

This is an OverTheWire game server.
More information on http://www.overthewire.org/wargames

backend: gibson-1

www. ver he ire.org

Welcome to OverTheWire!
If you find any problems, please report them to the #wargames channel on
discord or IRC.

--[ Playing the games ]--

This machine might hold several wargames.
If you are playing "somegame", then:

* USERNAMES are somegame0, somegame1, ...
* Most LEVELS are stored in /somegame/.
* PASSWORDS for each level are stored in /etc/somegame_pass/.
```

```
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
aaWecNkG4FhxJQxz07uiwzVP6bJiYS65
bandit14@bandit:~$
```

Bản chất của Level này chính là Private Key và Public Key và chính file `sshkey.private` mà em phải dùng lệnh `scp` kéo về máy Kali, sau đó cấp quyền `chmod` rồi mới đưa vào lệnh `ssh -i` để mở cửa.

Bandit Level 14-15

Đề bài yêu cầu ta mang mật khẩu của Level 14 vừa đọc được đem nộp cho một chương trình đang chạy ngầm trên port 30000 ngay tại localhost.

Bandit Level 14 → Level 15

Level Goal

The password for the next level can be retrieved by submitting the password of the current level to **port 30000 on localhost**.

Commands you may need to solve this level

ssh, telnet, nc, openssl, s_client, nmap

Helpful Reading Material

[How the Internet works in 5 minutes \(YouTube\)](#) (Not completely accurate, but good enough for beginners)

[IP Addresses](#)

[IP Address on Wikipedia](#)

[Localhost on Wikipedia](#)

[Ports](#)

[Port \(computer networking\) on Wikipedia](#)

Ở Level này, ta tương tác với một port tùy chỉnh là 30000 trên localhost. Trong môi trường quản trị mạng thực tế, các dịch vụ hệ thống thường chạy trên các cổng tiêu chuẩn (Standard Ports) được quy định sẵn trên toàn cầu để dễ dàng giao tiếp. Các dịch vụ và cổng thông dụng bao gồm:

- **Port 20/21 (FTP):** Dịch vụ truyền tải tệp tin (File Transfer Protocol).
- **Port 22 (SSH):** Dịch vụ điều khiển dòng lệnh máy chủ từ xa an toàn (đây chính là cổng kết nối ta sử dụng để chơi wargame Bandit).
- **Port 80 (HTTP):** Giao thức truyền tải dữ liệu web dạng văn bản thô (không mã hóa).
- **Port 443 (HTTPS):** Giao thức truyền tải dữ liệu web bảo mật (đã được bọc mã hóa SSL/TLS).
- **Port 3306 (MySQL):** Cổng mặc định cho hệ quản trị cơ sở dữ liệu MySQL.

Và em sẽ dùng lệnh nc (netcat) để kết nối và truyền dữ liệu thông qua giao thức TCP/UDP bằng lệnh `cat /etc/bandit_pass/bandit14 | nc localhost 30000`

Lệnh **nc** (**Netcat**) trong **Linux** là một công cụ dòng lệnh cho phép gửi và nhận dữ liệu qua kết nối mạng sử dụng giao thức **TCP** hoặc **UDP**. Đây là công cụ được sử dụng phổ biến bởi các quản trị viên hệ thống và mạng nhờ khả năng mô phỏng kết nối, kiểm tra dịch vụ, truyền dữ liệu và khắc phục sự cố.

```
bandit14@bandit:~$ ls
bandit14@bandit:~$ ls -a
.  ..  .bash_logout  .bashrc  .profile  .ssh
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14 | nc localhost 30000
Correct!
pbLYuZtTg4MgaqfJx8jbA9gKKGqM68A7
```

Bandit Level 15-16

Để lấy mật khẩu của Level 16 thì ta cần nộp mật khẩu của Level 15 cho cổng mạng 30001 trên localhost. Lần này, cổng mạng yêu cầu mọi dữ liệu truyền qua phải được bọc trong lớp mã hóa SSL/TLS.

In mật khẩu của Level 15 ra để copy:

cat /etc/bandit_pass/bandit15

```
bandit15@bandit:~$ cat /etc/bandit_pass/bandit15
pbLYuZtTg4MgaqfJx8jbA9gKKGqM68A7
bandit15@bandit:~$
```

Khởi tạo đường hầm mã hóa SSL/TLS đến cổng 30001 với lệnh

openssl s_client -connect localhost:30001

```
bandit15@bandit:~$ openssl s_client -connect localhost:30001
Connecting to 127.0.0.1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN=SnakeOil
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN=SnakeOil
verify return:1

Certificate chain
 0 s:CN=SnakeOil
 1 i:CN=SnakeOil
 a:PKEY: RSA, 4096 (bit); sigalg: sha256WithRSAEncryption
 v:NotBefore: Jun 10 03:59:50 2024 GMT; NotAfter: Jun  8 03:59:50 2024 GMT

-----
Server certificate
-----
BEGIN CERTIFICATE
MIIFBzCBAAwGjQYIKoZIhjEAQAEBAwEzERMAAGAA1UEAwM1U2Shaz2PwAwwihcNM3QwKjEwMDI0UWwhcNwzQmNjAA
MDM1OTUwWjATMREwQwVQVQQAhtbFrZU9pbDCCAlIwDQYJKoZIhvcNAQEBBQAD
ggIPADCCAgogggIBANI+PSQXm9Bj2IFIPsQbqZrB5Xm5ZJYaam7EIJ16Fxedf+
JXAv4o/FVq1ER4busvNwBMx2q8lAFn33h+RMTJRoMBdyBSZsc06JMLfXck4Pr
00gtGFf050jy3XdmFv/FPhvA3J0BscclDdm6Lb0dwhv93Q8MEPOV09sv4u54t/
jEjI+NHe+BjI/wDbyg7GL71BP1WPZpQnRE4Qz05rT5+bZVLvOOWUfW1n80FLaGRk
GmI0r5EU0Ud7HpyYoIQb1nlePGfPpHRkmdXTTEZexoxWAAm1VhPgqfB/Pnca+
vAJX71B0B3k1nmfV0Scsg/VAUR9AwSELeY+U0EWJaELVuntrJShEDITCh1VQ++
wnfJN0pam8ShopybUf3Xx7h1b4NwL8pvoK7Xtcv3J10Jf85nVpE+R8T0wacy
tHtJz57Ao7gvxDz6H8ADBLKJW67Uqon37a4M1260ADFMS+2vEADMSFP+f6l15mFB
18cY64Zaf60U8bJGK7BArDx56bRC3WfYUBIGWAFHeuB948BcshXY7baf5jjzPmgz
mq1zdrthQ831M0WQ110vUtkheAvkFFrLlH0M9S6ESANSFZnJ9Nhg9vV08wfhYC
x0W4qu+58R0U9FV23y7VUNg2AQ4UoG5kSHSE31BfqhImpJm1nGcR2L5PAgMB
AAGJuzBRMB0GA1UdGQwBBTP08kfze4P9EGxNuyk7+xDGfAYzAFBgNVHSMEDGAW
gBTP08kfze4P9EGxNuyk7+xDGfAYzAP8gNVHRMBAf8EBTADAQH/MAGCSqGSIb3
DQEBChUAA4ICAQAKhowtmcGy1Lnhz1Le97Mq2+5u13QgYVwfx/KY0Xxv2T8ZmcR
Ae9Xfht4j5A0U0K10X9zgdG3h13LNEVte2ZWj0NF4NkE8xqg7hm08wctjJd
taqEW/Jp80X+88BtNYK9NZsvDg2YRcvOHConEMjwvEL7tQK0m+GvyqFLyg61nrhx
egH+abucTKxabfCwSE+Vx0uJVMqcbxvBAWNKz9v34V5Hn7/DNax1Jfko+nREw60a
/AUFjNnO/FPJap+d68H1LdzMH1P5s+yJGid+6Zx9FCnt9qZydw13M1qg3nDn0DXw
+Z68ZmfJYlGPCASZ0QyMY4Y4nAG0n8qzFamQf3+Jf8Lbs4+M60pnm1Mk1U
jWLWKA9MLb0Nua3j1PMVYIYK9d08ZbFakwo0F3SLxLqLF8r1o1GGCEVSHL25S2
txw10+dw9WmGcwo1LbZ5BRJH4TIBFFtoB0G0LoEJ10C+UPwS8CDng3B4TyrZqElD3
PH87W+Et1t/Nepoc/Eoaux9Pp5VPXP+qWgmh1r/hv70Sg8hrKyhkXZ8+1uK7
t1WC/XMm0pL0s0vW1Za33J611vgAPXlyt4uG1lvB2Cuc93XVRj0p0wEqZT
USEyeuFg5RKYwAP17ykw1PW72APL4MLonEVz+QX0Sx6eyhImp1VZC115Cg==
-----
subject=CN=SnakeOil
issuer=CN=SnakeOil
```

```

No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: rsa_pss_rsae_sha256
Negotiated TLS1.3 group: X25519MLKEM768

SSL handshake has read 3191 bytes and written 1613 bytes
Verification error: self-signed certificate

New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Protocol: TLSv1.3
Server public key is 4096 bit
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 18 (self-signed certificate)

Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol : TLSv1.3
    Cipher : TLS_AES_256_GCM_SHA384
    Session-ID: E4A2A085DF56D7724DDA16ADCDE1B557299D38FC82A205CB4CCE1F06CFCE459A
    Session-ID-ctx:
    Resumption PSK: B0F2EAA6BE5112C066FE05DD462DBC1269CB7DFE186C2442FB0295B226E7C004819D01F445E7DE7831E80D6E940671E
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
0000 - d3 36 31 7d b1 9c 35 85-7c 6b 2c a8 28 1c e7 d8 .61}..5.|k,.( ...
0010 - b2 bf 59 d2 28 02 90 90-21 b4 7c 1c c8 9d 84 25 ..Y.(...!.)....%
0020 - 7f 6a d5 5b 0e 11 ff 52-04 75 2f f7 0d 99 50 11 .j.[...R.u/...P.
0030 - 0f 36 cf 57 c8 59 af 22-7f 20 52 45 c8 cb e0 33 .6.W.Y.". RE...3
0040 - 3f 43 7c e5 63 81 81 6b-68 97 ab e9 1d 82 ed 18 ?C|.c...kh.....
0050 - 03 0e 4d 89 64 d9 cf 13-4c be b9 02 7c a6 7c 44 ..M.d...L...|.D
0060 - 02 a5 ec 86 6b 69 46 39-10 53 fb d9 9c e5 a9 93 ....kif9.S.....
0070 - 57 5c 1f 70 72 d5 99 13-0c ba 47 f5 de 60 27 1f W|.pr.....G...".
0080 - 45 28 92 f4 cd 3f 51 82-85 b6 b5 6c b6 8a b8 73 E( ... ?Q...l...s
0090 - d1 00 5f ef e1 39 18 16-2f ff a6 00 6d 9d bd 21 ...9.../...m...!
00a0 - ce 2d 4b 72 94 d9 b2 a4-b7 22 64 67 9a d1 24 9d ..Kf...."dg...$.
00b0 - 9c b2 42 3c 76 f9 15 50-98 1a c4 eb 9a 37 89 24 ..Bcv...P.....7.$
00c0 - 35 9a 22 b0 f1 06 f0 0f-b8 b8 3d d7 be a5 ae b1 5.....-.....
00d0 - df 69 90 bf 0c 97 5b 7d-e8 68 15 36 48 70 44 5a .i....[.].h.6HpDZ

Start Time: 1787329687

```

```

Timeout : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0

read R BLOCK

Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol : TLSv1.3
    Cipher : TLS_AES_256_GCM_SHA384
    Session-ID: DF821DB71F0B1A831007C7A9473586ECF4E1CBA6AAD0E636569DD9C8DF22E09B
    Session-ID-ctx:
    Resumption PSK: 06C344477C59EEB286A48D52A74401643E226A4DE4C2647B4FED61DA2046EA7221735693E575D833747FEC5B81FF65E
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
0000 - d3 36 31 7d b1 9c 35 85-7c 6b 2c a8 28 1c e7 d8 .61}..5.|k,.( ...
0010 - e7 b9 d9 dd d6 a2 59 3b-60 52 14 83 24 aa 55 0d ....Y;".R..$.U.
0020 - ac 7b 47 89 78 be af 69-4e 1e 7b 3f aa c9 02 40 .{G...iN.{?...@
0030 - 7b a8 b0 dd 03 ba eb 6b-93 1d da 6f cc 54 f9 a5 {.....k...o.T...
0040 - 89 b4 53 7a 24 e4 79 70-b4 bc 7a be 3f e4 70 bd ..S2$.yp...z?.p.
0050 - 7e da b4 e2 c3 d7 4a 43-9f 8c 7c 29 36 1c ce 8c ~.....JC...l)6...
0060 - cb 8c 1e 49 9d 4a 0b 27-56 1c dc 51 97 e9 80 f1 ...I.J.'V...Q....
0070 - 1d 5e 82 f6 b6 71 59 04-a6 e2 4d 5c 78 bd 6b ee .^...qY...Mx.k.
0080 - 4d d9 9f 49 b4 8f 72 1f-af 73 fd 5f 67 b7 fe 66 M..I...r...s_g..f
0090 - 96 fe 4c 33 ca 6c c1 ab-80 d9 36 55 ac bd 63 92 ..L3.l....6U...c.
00a0 - c4 42 5d 4d 30 99 f3 0f-8c 95 c5 f8 0a f0 7a a5 .B]M0.....z..
00b0 - 57 52 8c 82 d3 b0 c5 19-63 4f 0a 43 b9 69 3e ea WR.....c0.C.i3..
00c0 - 9b 4e 9d cb 87 93 e2 10-cd d2 b1 a1 ee 79 87 9d .N.....y..
00d0 - 0b 02 f7 20 6c f6 fc 39-e7 49 d5 ad 1c 11 3e ff ...l..9.I.....>.

Start Time: 1787329687
Timeout : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0

read R BLOCK

```

Có thể thấy lệnh `openssl s_client` hiển thị các thông số mã hóa chi tiết. Nó xác nhận rằng ta đang giao tiếp qua giao thức `TLSv1.3` với bộ mã hóa `TLS_AES_256_GCM_SHA384`. Hệ thống cũng sinh ra các phiên làm việc (để duy trì kết nối. Điều này chứng tỏ đường ống bảo mật đã được dựng lên thành công.

Ở dưới cùng của màn hình, tiến trình kết thúc bằng các thông số xác thực chứng chỉ (Verify return code: 18), trạng thái Max Early Data: 0, dòng chữ `read R BLOCK`

Cuối cùng em chỉ nhập pass level 15 để nhận được pass ở level 16

```
read R BLOCK
pbLYuZtTg4MgaqfJx8jbA9gKKGqM68A7
Correct!
kS0Hf0u5HiXFwKMKFqXvPd0TNGGa0X8V

closed
bandit15@bandit:~$
```

Sau khi làm việc với cả 2 lệnh kết nối tới server như nc và openssl s_client ở 2 Level này thì có thể so sánh như sau:

	nc (Netcat)	openssl s_client
Giao thức hỗ trợ	Hoạt động bằng cách kết nối và truyền dữ liệu thông qua giao thức TCP/UDP cơ bản.	Thiết lập đường truyền an toàn được bọc trong lớp mã hóa SSL/TLS.
Trạng thái dữ liệu	Do là không được mã hóa, dạng thô nên bất kỳ ai cũng có thể rình rập trên mạng lưới cũng có thể đọc được nội dung gói tin.	Truyền dữ liệu mã hóa. Ai chặn bắt gói tin cũng chỉ thấy một chuỗi ký tự hỗn độn không thể giải mã.

Bandit Level 16-17

Ở Level yêu cầu scan toàn bộ port từ 31000 đến 32000 và tìm ra port chạy ssl để gửi password của level hiện tại và từ đó sẽ nhận được password của level sau.

Bandit Level 16 → Level 17

[Donate!](#) [Help!?](#)

Level Goal

The credentials for the next level can be retrieved by submitting the password of the current level to a port on localhost in the range 31000 to 32000. First find out which of these ports have a server listening on them. Then find out which of those speak SSL/TLS and which don't. There is only 1 server that will give the next credentials, the others will simply send back to you whatever you send to it.

Helpful note: Getting "DONE", "RENEGOTIATING" or "KEYUPDATE"? Read the "CONNECTED COMMANDS" section in the manpage.

Commands you may need to solve this level

ssh, telnet, nc, ncat, socat, openssl, s_client, nmap, netstat, ss

Helpful Reading Material

Port scanner on Wikipedia

Dựa vào danh sách gợi ý, em sẽ kết hợp nmap để vẽ bản đồ các cổng đang mở, và openssl s_ để mở lớp mã hóa giống hệt Level trước đó

Đầu tiên em dùng lệnh `nmap -p 31000-32000 bandit.labs.overthewire.org` với `-p 31000-32000`: Khoanh vùng mục tiêu, chỉ bắt Nmap quét các cổng trong dải số này để tiết kiệm thời gian.

Cách Nmap hoạt động: Để vẽ bản đồ các cổng đang mở, Nmap gửi các gói tin mạng đặc biệt (thường là gói TCP SYN) đến các cổng mục tiêu. Dựa vào cấu trúc (flags của gói tin phản hồi từ Server, Nmap sẽ phân tích và kết luận cổng đó đang Mở (Open), Đóng (Closed) hay Bị lọc bởi tường lửa (Filtered).

Cơ chế tìm phiên bản của tham số -sV: Tham số -sV đóng vai trò dò tìm chính xác dịch vụ/phiên bản. Khi cờ này kích hoạt, Nmap không chỉ xem cổng có mở hay không mà sẽ thiết lập một kết nối TCP hoàn chỉnh. Tiếp đó, nó gửi các gói tin "mồi nhử" (probes) vào cổng đó. Dựa trên chuỗi dữ liệu phản hồi (banner) nhận được, Nmap đem đối chiếu với cơ sở dữ liệu nhận dạng khổng lồ (nmap-service-probes) để định danh chính xác phần mềm đang sau cổng là Echo hay SSL.

```

bandit16@bandit:~$ nmap -sV -p 31000-32000 bandit.labs.overthewire.org
Starting Nmap 7.90 ( https://nmap.org ) at 2026-08-21 17:21 +0000
Nmap scan report for bandit.labs.overthewire.org (127.0.0.1)
Host is up (0.00015s latency).
rDNS record for 127.0.0.1: localhost
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
31046/tcp  open  echo
31518/tcp  open  ssl/echo
31691/tcp  open  echo
31790/tcp  open  ssl/unknown
31960/tcp  open  echo
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port31790-TCP:V=7.90T=SSLH=7X0-B/21TTime=6A88946KPe=x86_64-pc-linux-g
SF:nuKr(GenericLines,32,"Wrong!\x20Please\x20enter\x20the\x20correct\x20cu
SF:rrent\x20password\\.\\n")Kr(GetRequest,32,"Wrong!\x20Please\x20enter\x20t
SF:he\x20correct\x20current\x20password\\.\\n")Kr(HTTPOptions,32,"Wrong!\x20
SF:Please\x20enter\x20the\x20correct\x20current\x20password\\.\\n")Kr(RTSPRe
SF:quest,32,"Wrong!\x20Please\x20enter\x20the\x20correct\x20current\x20pas
SF:sword\\.\\n")Kr(Help,32,"Wrong!\x20Please\x20enter\x20the\x20correct\x20c
SF:urrent\x20password\\.\\n")Kr(FourOhFourRequest,32,"Wrong!\x20Please\x20en
SF:ter\x20the\x20correct\x20current\x20password\\.\\n")Kr(LPDString,32,"Wron
SF:g!\x20Please\x20enter\x20the\x20correct\x20current\x20password\\.\\n")Kr(
SF:SIPOptions,32,"Wrong!\x20Please\x20enter\x20the\x20correct\x20current\x
SF:20password\\.\\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 122.78 seconds
bandit16@bandit:~$

```

Ở đây em thấy Cổng 31046, 31691, 31960: Bị dán nhãn echo. Đây là các cổng bẫy thô, bạn ném mật khẩu vào thì nó chỉ nhại lại y hệt (vọng âm).

Cổng 31518: Được dán nhãn ssl/echo. Mặc dù có bọc mã hóa SSL, nó vẫn chỉ là một cái bẫy nhại lại nội dung.

Cổng 31790 (Mục tiêu đích): Nmap báo ssl/unknown và cổng 31790 phản hồi

Sau đó dùng lệnh openssl s_client -connect localhost:31790 để kết nối với cổng 31790

```
bandit16@bandit:~$ openssl s_client -connect localhost:31790
Connecting to 127.0.0.1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN=SnakeOil
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN=SnakeOil
verify return:1
---
Certificate chain
 0 s:CN=SnakeOil
  i:CN=SnakeOil
  a:PKKEY: RSA, 4096 (bit); sigalg: sha256WithRSAEncryption
  v:NotBefore: Jun 10 03:59:50 2024 GMT; NotAfter: Jun  8 03:59:50 2034 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIFBzCCAa+gAwIBAgIUaBz7DBxA0IfojaL/WaJzE6Sbz7cwDQYJKoZIhvcNAQEL
BQAwEzERMA8GA1UEAwYIU25ha2VPaWwwHhcNMjQwNjEwMDM1OTUwWhcNMzQwNjA4
MDM1OTUwWjA1MREwDwYDVQDDAhTbmFrZU9pbDCCAiiwDQYJKoZIhvcNAQEBBQAD
ggIPADCCAgoCggIBANI+P5QXm9Bj21FIPsQqbqZRb5XmSZZJYaam7EIJ16Fxedf+
jXAv4d/FVqiEM4BuSNsNmMeBMx2Gq0LAfn33h+RMTjRoMb8yBsZsC063MLfXck4p+
09gtGP7BS6Iy5XdmfY/fPHvA3JDEScdLDDmd6LSbdwhv93Q8M6POVO9sv4HuS4t/
jEjr+NhE+Bjr/wDbyg7GL71BP1WPZpQnRE40zoSrt5+bZVLvODUFWinB0fLaGRk
GmI0r5EU0Ud7HpYyoIQbiNlePGfPpHRKnmdXTTEZEoxeWWAaM1VhPGqfR/Pnca+
vAJX7iB0b3kHimfv0ScsG/YAUR94wSELeY+ULEWJaELVUntrJ5HeRDiTChivQ++
wnnjNbepaW6shopybUF3XXfhIb4NvwLWpvoKFXVtcVjlOuJF0snVvpE+MRT0wacy
tHtjZs7Ao7GYxDz6H8AdBLKJW67uQon37a4MI260ADFMS+2vEAbNSFP+f6ii5mrB
18cY64ZaF6oU8bjGK7BARdx56bRc3WFyuBIGWAFHEuB948BcshXY7baf5jjzPmgz
mq1zdRthQB31MOM2ii6vuTkheAvKfFf+llH4M9SnES4NSF2hj9NnHga9V08wfhYc
x0W6qu+S8HudVF+V23yTvUNgz4Q+UoGs4sHSDEsIBFqNvInnpUmtNgcR2L5PAgMB
AAGjUzBRMB0GA1UdDgQWBbTPo8kfze4P9EgxNuyk7+xDGfTAYzAFBgNVHSMEGDAW
gBTPo8kfze4P9EgxNuyk7+xDGfTAYzAPBgNVHRMBAf8EBTADAQH/MA0GCSqGSIb3
DQEBChUAA4ICAQAKHomtmcGqyiLnhziLe97Mq2+Sul5QgYVwfx/KY0Xxv2T8ZmcR
Ae9XFhZT4jsAOUDK10X9aZgDGJHJLNEVTe9zWv1ONFfNxEBxQgP7hhdBwdtj6d
taqEW/Jp06X+08BtNYK9NZsvDg2YRcvOHConeMjwvEL7tQK0m+GVyQfLYg6jnrhx
egH+abucTKxabFcWSE+Vx0uJYMqcbXvB4WNKz9vj4V5Hn7/DN4xIjFko+nREw60a
/AUFjNn0/FPjap+d68H1LdzMH3PSs+yjGid+6Zx9FCnt9qZydW13Miqg3nDnODXw
+Z682mQFjVLGPcA5ZOQbyMKY4tNazG2n8qy2famQT3+jF8Lb6a4NGbnpeWnLMkIu
jWLWIka9MlbdNXuajjPNVyyIK9gdoBzbfakwo0fSsLxEqlf8rio1GGcEV5Hlz5S2
txwI0xdW9MWeGwoiLbZSbRJH4TIBFFtoBG0LoEJi0C+UPwS8CDngJB4TyrZqElD3
rH87W+Et1t/Nepoc/Eoaux9PFp5VPXP+qwQGmhir/hv70sgBhrkYuhkjjxZ8+1uk7
tUWC/XM0mpLoxsg6vVl3AJaJe1ivdA9xLytsuG4iv02Juc593HXYR8y0pow0Eq2T
U5EyeuFg5RXYwAPI7ykw1PW7zAPL4MlonEVz+QX0Sx6eyhimp1VZC11SCg==
-----END CERTIFICATE-----
subject=CN=SnakeOil
issuer=CN=SnakeOil
```

```

No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: rsa_pss_rsae_sha256
Negotiated TLS1.3 group: X25519MLKEM768

SSL handshake has read 3191 bytes and written 1613 bytes
Verification error: self-signed certificate

New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Protocol: TLSv1.3
Server public key is 4096 bit
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 18 (self-signed certificate)

Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol : TLSv1.3
    Cipher : TLS_AES_256_GCM_SHA384
    Session-ID: 7E87168F542E505349A8D07FC9B2B2F87024C3EA3D82208D68FA329808A97CB0
    Session-ID-ctx:
    Resumption PSK: 06751D33B16D71F21E31ACC3FE35CD87AC186F0EF53426C9F85A1E8DAE078E7E36F08323B249871F0623BFC7425376E9
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
0000 - 92 78 b4 38 57 bd a5 5a-51 58 fa 5f ae e4 25 2a    .x.8W..ZQX...%*
0010 - ac ff 0d 8a 4c 71 c2 02-56 35 4c fc 97 70 40 59    ....Lq..VSL..pQY
0020 - 6d e7 79 e2 2c 5b c8 46-59 7c 1a 46 8e 9a d5 0b    m.y.,[.FY].F...
0030 - 47 ef 54 76 1e cf ee 20-fa 97 d3 ce d9 66 a4 02    ..TV... ..cf..
0040 - 28 59 79 a8 86 dc ee 4b-33 25 ba ef 28 c6 be 86    (Yy....K3%, (...
0050 - 1e f7 12 b9 1c b6 14 be-12 06 27 e2 98 82 87 f2    .....
0060 - af 55 a2 27 db d7 fb 99-0d b4 6a 0d 41 dd b8 07    .U.'.....}.A...
0070 - 8b e3 74 78 2f 0a 88 f1-df a6 56 fe d9 a9 2e 66    ..tx/.....V....f
0080 - ee 14 f7 b4 5a ee 1b 41-29 dd 3e 35 47 64 06 33    ....Z..A).>5Gd..3
0090 - d7 b4 38 e9 66 fc 6b 1d-26 99 e7 5c 53 a6 cb f5    ..8.f.k.ß..VS...
00a0 - ca be 74 8a 12 f0 8c bd-66 36 d0 b0 b2 48 d5 fe    ..t.....f6...H...
00b0 - 67 d5 7b e6 3f 2d 0b b8-6a 7a 40 f2 c9 1a c6 0b    g.{?-..jz0.....
00c0 - a0 df c6 dd a0 0c 46 c1-67 c4 77 18 9c 82 29 a7    .....F.g.w....).
00d0 - f5 06 8a 28 d5 8a 65 57-26 04 50 c7 da 75 14 40    ... (...ew0.P...u.0

Start Time: 1787333310

```

```

Start Time: 1787333310
Timeout : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0

read R BLOCK

Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol : TLSv1.3
    Cipher : TLS_AES_256_GCM_SHA384
    Session-ID: 8DEB3648060AD076CB10B2560089065F332F06E0088545216C3B279A8BF5D7F3
    Session-ID-ctx:
    Resumption PSK: 38780FA09AE7E30A2D7599E028B171D842BA4AAB946565A27482CF6613D2E0D1BF4EDC1D5D37DB7BC30004391FC32918
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
0000 - 92 78 b4 38 57 bd a5 5a-51 58 fa 5f ae e4 25 2a    .x.8W..ZQX...%*
0010 - aa 31 b7 3d 77 b5 c5 b0-25 aa 6d 3e fd cb c5 76    .1.=w...%.m>...v
0020 - 81 b5 dd 27 4e c5 5d 80-eb 2c cb 6d a7 53 32 60    ...'N.]...,.m.S2'
0030 - 94 15 b2 14 87 24 08 b1-6e 96 3d e3 d3 e3 19 e2    .....%.n.=.....
0040 - 3c 0d 3a 04 bc 1c da 67-47 57 2c d4 aa f9 78 3c    <.:....gGW, ...x<
0050 - a4 07 72 65 e4 01 ca 3c-d7 43 74 59 e7 f0 0f 5f    ..re...<.CtY..._
0060 - 4f 16 7c 01 56 d5 28 08-fe 04 29 4a 6b 2e bc 9a    0.[.V.(... )Jk...
0070 - fb 0b 58 cd 33 a5 b7 f0-27 21 25 d9 1d dc 3e 7f    ..X.3 ... '!%...>.
0080 - 11 0f 4f f6 fc fd 71 49-8a 9c 68 76 8b 53 e3 7e    ..0 ... qI ..hv.S.~
0090 - eb 62 fd 00 8f c3 1b 86-e9 c5 cf 3f ed 9c dd f8    .b.....?....
00a0 - 87 69 f4 fb dd 2a 8f 42-f4 c1 a9 b9 7a d8 7f 36    .i...*.B.....Z..6
00b0 - 02 a6 cb 52 8e 45 8c 4b-2e e6 67 1a b5 3c a3 b8    ...R.E.K..g..<..
00c0 - d5 ae 40 9f cc 48 56 77-f7 3e 9e e2 d8 a8 cc a2    ..0..HVw.>.....
00d0 - c5 1d 03 29 7e 9a d6 ae-8d 87 8f 00 8c 50 a7 69    ... )-.....P.i

Start Time: 1787333310
Timeout : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0

read R BLOCK

```

Sau đó em nhập mật khẩu ở Level trước này để lấy mật khẩu ở level sau

Nhưng khác ở level trước đó thì lần này lại xuất ra từ khóa “KEYUPDATE” và báo

rằng password sai là do Mật khẩu Level 16 của ta là

kS0Hf0u5HiXFwKMKFqXvPdOTNGGa0X8V bắt đầu bằng chữ cái k.

Đúng như gợi ý từ đề bài (hãy đọc phần CONNECTED COMMANDS), khi công cụ openssl s_client đang chạy ở chế độ tương tác mở, nó sẽ lắng nghe các phím tắt. Phím k đứng đầu dòng được nó hiểu là lệnh yêu cầu cập nhật khóa bảo mật nội bộ (KEYUPDATE) thay vì gửi một ký tự văn bản.

Helpful note: Getting "DONE", "RENEGOTIATING" or "KEYUPDATE"? Read the "CONNECTED COMMANDS" section in the manpage.

```
read R BLOCK
kS0Hf0u5HiXFwKMKFqXvPdOTNGGa0X8V
KEYUPDATE

Wrong! Please enter the correct current password.
closed
bandit16@bandit:~$
```

Do đó em chỉnh lại lệnh và thêm flag -quiet

```
echo "kS0Hf0u5HiXFwKMKFqXvPdOTNGGa0X8V" | openssl s_client -connect localhost:31790 -quiet
```

```
bandit16@bandit:~$ echo "kS0Hf0u5HiXFwKMKFqXvPdOTNGGa0X8V" | openssl s_client -connect localhost:31790 -quiet
Connecting to 127.0.0.1
Can't use SSL_get_servername
depth=0 CN=SnakeOil
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN=SnakeOil
verify return:1
Correct!
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktZjEAAAABG5vbmUAIAAAEbm9uZQAAAAAAAAABAAAblwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAvdSaw8j1FQ2Djtb0PGIEVtqEG5kt3g71uDIxg42vRN2MwWRVnGQ
t4k9T91DWa1snn+6iARCKhEzW231WAGKvc0Sd0+6/gCp1Egpl4o4L+xf5gPNo7A20qjN67
HhY6i71GBjyU8np6vEtKf3WZnZtuxpCMpyhSy7m6p1pJfddkEUCX21hNWmy2SAZ0fBub
3M1hrcar5cA4pCF32Amj5s0P4yRbdeRh3vZTCNjKe2z+ze4jf2/Y/uNdmiXdaMuD8to4Y
f73y1XL/-+ohzasOYMOiNFvvr8gk00c11xuTndbGnmuiFf3Vp1qtJNB600EWBt0H4xL7/WX
wEQ0/3EbpjUxgm3ZyU5FmD4Gh119w4FqMD+RT9T3AVuzX8NM1FiIAkQMe0b34qF71Tjd
Tcc2Ve7Ywaakm793YFmw1rYd9QORxmjqUO+H6Yn9XLfmpRkF3vVf3NfvekRtV5Fm7Le9wr
ipXLjZiKhFh6echM3pInIjJh1ZAgB/CDPvRdLhtAAAF1PHONUjxzjVIAAAAB3NzaC1yc2
EAAAGBAL3UmsP19RUng47W0DXohFbahBuZLd409bg5YsYONr0TdJl1kV2xkLeJPU/bQImo
zJ5/u10EQpIRM8Nt9Vg011XNEndPuv+ggdRIKeK0J3fsX+YDzaOwNjqo6jeux4cui09RgY8
1A26erxL2CN1mZmbbsaQjD8h0su5uepYqSRXXShD1A19tYTV1stkgGUB0bm9ZNYa3Gq+XA
OK0hSdgJo0rDj+Mkw3REYd72UxjYyntsf3uI39v2P7jXZosXWgDLg/LaOGH+ycpVy//qI
c2rDmDNIjRb6/1JDjnNdcbkzXWxjZrTRX91adarSTQetNBFqwbFR+MZe/1188ENP9xG6Y1
MRpt2cLF0RZg+AhodZfc0BaJA/KU/U9wFbs1/DTNRYiAJEDHTG9+Khe4k43U3PtLXu2MGm
pJU/SWBZ9Iq2HfUDKcZo6LDvh+mJ/cSxZqUZBY71X9zX73pEbVeRZu5XvcK4qV5Y2dYZB3
x+nn1TN6SDYiSR4mQIAfwgz1UXS4bQAAAMBAEAAAGACMy4N+cy5TzXIkf28zXtHJGymi
bpg20IHIYkBMm8sXX+Usysk1D2GaBND9f4JsnC9S7Qv2dGOUrrgKqrR4tRuZM8XXG42
KS6fMm9gd1LPKZke/gK4L1C1VDmBK1KmXezahFh1jXyMnizVCX4qDAHVLSu/oc6UyZxiH
Dpw2J02qqR34s1wsjdUklonOYCaOPqZySD15vbwBTL80D10taFwhG5yqVMmaZIZ4GyF
HEqzv06Sw04Lor/3vICZJ5YLUVa2GEEx51r1Np/fb3C+zKe37+HPf5LhDps20WXNf1D/N
KhPtQqhaNoATORB+64nNw66/515vs1h87Jm4Yy/mJjJe0uR8cC4nnqXG80y6LIFzbNQN
DastUidaMaqpswS49R5/Uq2YY0jbu+YCbBjz8qaz8eUhlMs0I6b2XGwtr4rP9fENwrxqs
z3BYvWzI4t8G/Og2ESZvn+DCTAuc/+NtIeLDTeJjsUgkU5Xm4Xdmz1y0S8wRqTRpJAAA
wQCie/31KZCUQJfwdZ1L161XZ9ANreda++0LKvQVGmfjnPawpc21o/n0IkjE5Rch9bHkR
n/Pmm228x2TaWcq0FsyP9VnZQIw3LYPZxxouvV4ODFeThi6dJi9X7WnyvNVaeQam5Mqzd
6eI4l9F6p43j1vvRLc7IrEDMjSXMcN1UbbvEfa/143fpHZer9q+9qARUSLIdr8D6zde3l0
r88E020Y2rwn1BzjP2z2z+3GPTcfYPM+pLPT30gAjdgVr7pEAAADBAN2qsjh6rfGKH1ou
n+pf1TUIXLzpnY+icwYcotvfHjweF1KwowzqnNjG0oLJqc5B602g8FbeIn3a1v/896Ybn3
WXXYs1cXGyYwXkw5nWASWS8GMVEpjTgvW6hnrWmDVEPUW84wsgZ1yGnL0InHq3SmGMVe
7FLV0o2LD393RW/2RCM28mX/SWGLst9IunzxoeHGxJ0bKWV6C2IgQj8zHDpuE/6TwdDeFS
3KWM+JyggNB+EEssW7Tu+N2H+3mgLNBwAAAMEA2zuRe03x3LioX2U502ZmawKeajDKAUWh
OmfbD3ab8psuVc1lydLWQfmJmJ7xyAEtm02KtG6ax6AEd4PLAgDC504v+bmLPjdvdSwqGk
//v0MxuDy+Uy3m3ox+MHK2KRq5Z3dj9DpX6AF5iMbyiQYA69nsBumqt04Ihe8CFYHa9uG
KLE1QobuX5Wx6cWa0sc1j61vpavDEwMUT8LEmfQjN1rF1LM1NENBQhtd+ikJmYwB01/5
PFos/2C+rbNuHjAAAADn11ZHLAbg9jYwXob3N0AQIDBA=
```

Sau đó copy từ -----BEGIN OPENSSH PRIVATE KEY-----

...

-----END OPENSSSH PRIVATE KEY----- dùng lệnh `chmod 600 /tmp/bandit17.key` để tạo file sau đó cấp quyền `chmod 600 /tmp/bandit17.key` và dùng lệnh `ssh -i /tmp/bandit17.key bandit17@localhost -p 2220` để level tiếp theo

```
(kali㉿kali)-[~]
$ ssh -i /tmp/bandit17.key bandit17@bandit.labs.overthewire.org -p 2220

[bandit17@bandit17 ~]$

This is an OverTheWire game server.
More information on http://www.overthewire.org/wargames

backend: gibson-1

www. ver he ire.org

Welcome to OverTheWire!

If you find any problems, please report them to the #wargames channel on
discord or IRC.

--[ Playing the games ]--

This machine might hold several wargames.
If you are playing "somegame", then:

* USERNAMES are somegame0, somegame1, ...
* Most LEVELS are stored in /somegame/.
* PASSWORDS for each level are stored in /etc/somegame_pass/.

Write-access to homedirectories is disabled. It is advised to create a
working directory with a hard-to-guess name in /tmp/. You can use the
```

Bandit Level 17-18

Sau khi đăng nhập vào bandit17, trong thư mục home có 2 file:

```
bandit17@bandit:~$ ls
passwords.new passwords.old
bandit17@bandit:~$
```

Dựa vào gợi ý của đề bài em sẽ chạy lệnh diff và khi chạy diff, công cụ sẽ phân tích hai file và cho biết những dòng nào cần thêm, xóa hoặc chỉnh sửa để tệp thứ nhất trở thành bản sao nội dung của tệp thứ hai.

<	Dòng thuộc file thứ nhất
>	Dòng thuộc file thứ hai

```
bandit17@bandit:~$ diff passwords.old passwords.new
42c42
< qOg5pVOjPx9x9VccyYBADiT4xxyoUB8D
___
> OQxXZjELndr90zuhOTDYBEomI0SZITXI
bandit17@bandit:~$
```

Từ đó có thể suy ra

Dòng < qOg5pVOjPx9x9VccyYBADiT4xxyoUB8D là nằm trong file passwords.old và dòng > OQxXZjELndr90zuhOTDYBEomI0SZITXI là nằm trong file passwords.new và cũng là password cho level tiếp theo

Ở đây nếu đăng nhập bằng cách thông thường sẽ bị Byebye! Là do file `.bashrc` trong Bandit Level 18, họ cố tình sửa `.bashrc` để shell thoát ngay sau khi đăng nhập.

Do đó em chạy lệnh kèm theo lệnh em muốn sử dụng là ls để liệt kê thông tin file ssh bandit18@bandit.labs.overthewire.org -p 2220 ls

Sau đó đăng nhập mật khẩu mà em có được ở level trước đó

Sau đó em sẽ đăng nhập lại kèm theo lệnh cat readme

ssh bandit18@bandit.labs.overthewire.org -p 2220 cat readme và từ đó lấy đc mật khẩu

```
(kali㉿kali)-[~]  
$ ssh bandit18@bandit.labs.overthewire.org -p 2220 cat readme  
  
      _-_-_-_-_-_|_-( )_--  
    /| | \/_|_/| |\__|\_/\_||_|\_/  
   /| | \/_|_/| |\__|\_/\_||_|\_/  
  /| | \/_|_/| |\__|\_/\_||_|\_/  
 /| | \/_|_/| |\__|\_/\_||_|\_  
/_._\/_\_,_|_|_|_\,\_|_|_|_\,  
  
This is an OverTheWire game server.  
More information on http://www.overthewire.org/wargames  
  
backend: gibson-1  
bandit18@bandit.labs.overthewire.org's password:  
KpsOfPkcP7i1FllExk2QEjyt6dw8dxZI  
  
(kali㉿kali)-[~]  
$
```

Còn về lý do hai lệnh `ssh bandit18@bandit.labs.overthewire.org -p 2220 cat readme` và `ssh bandit18@bandit.labs.overthewire.org -p 2220 ls` vẫn hoạt động là do khi sử dụng `ssh bandit18@bandit.labs.overthewire.org -p 2220` thông thường, SSH sẽ xác thực tài khoản `bandit18` rồi mở một interactive shell. Khi Bash khởi động, nó đọc file `~/.bashrc`, và `.bashrc` của bài đã được chỉnh sửa để làm shell thoát, khiến kết nối bị đóng.

Trong khi đó, với `ssh bandit18@bandit.labs.overthewire.org -p 2220 ls` hoặc `ssh bandit18@bandit.labs.overthewire.org -p 2220 cat readme`, SSH xác thực tài khoản bandit18 rồi yêu cầu máy chủ thực hiện trực tiếp command `ls` hoặc `cat readme`. `ls` dùng để kiểm tra và tìm file `readme`, còn `cat readme` dùng để đọc nội dung file. Sau khi command thực hiện xong, SSH kết thúc kết nối.

Ở đây em đã vượt rào cản .bashrc ép thoát shell bằng cách truyền trực tiếp lệnh đơn lẻ (như ls hay cat readme) vào thẳng cú pháp kết nối SSH để máy chủ thực thi rồi đóng kết nối. Tuy nhiên, để mở rộng kỹ thuật và lấy được một shell tương tác (Interactive Shell) hoàn chỉnh – cho phép gõ nhiều lệnh liên tiếp mà không bị văng ra ngoài, em có thể sử dụng cú pháp: `ssh bandit18@bandit.labs.overthewire.org -p 2220 -t /bin/sh`

Giải thích cơ chế: Tham số -t (force pseudo-terminal allocation) ép máy chủ SSH cấp cho ta một giao diện terminal ảo. Bằng cách gọi trực tiếp /bin/sh ở cuối lệnh, ta yêu cầu hệ thống tạo ra một phiên bản shell nguyên thủy. Cách làm này giúp lách hoàn toàn qua tiến trình nạp file cấu hình .bashrc độc hại, từ đó giữ được phiên làm việc tương tác ổn định trên server.

```
(kali㉿kali)-[~]
└─$ ssh bandit18@bandit.labs.overthewire.org -p 2220 -t /bin/sh
```

EXERCISE

This is an OverTheWire game server.
More information on <http://www.overthewire.org/wargames>

```
backend: gibson-1
bandit18@bandit.labs.overthewire.org's password:
$ ls
readme
$ cat readme
Kps0fPkCP7i1FlIEk2QEjyt6dw8dxZI
$ |
```

Bandit level 19-20

Dùng ls để xem trong home có file nào.

```
bandit19@bandit:~$ ls
bandit20-do
bandit19@bandit:~$
```

Dùng ls -l bandit20-do để kiểm tra quyền của bandit20-do

```
bandit19@bandit:~$ ls -l bandit20-do
-rwsr-x--- 1 bandit20 bandit19 14880 Jun 24 14:58 bandit20-do
bandit19@bandit:~$
```

Đề ý phần -rwsr-x---

-: Ký tự đầu tiên cho biết đây là một file thông thường.

rws – Quyền của Owner: r là Read (đọc), w là Write (ghi), còn s là SetUID. Chữ s xuất hiện thay cho x (Execute – thực thi) cho biết file đã được bật SetUID. Khi một user thực thi file này, chương trình sẽ chạy với effective UID của chủ sở hữu file, thay vì chỉ sử dụng quyền của user đang thực thi.

r-x – Quyền của Group: r là quyền đọc, - là không có quyền ghi, và x là quyền thực thi.

--- – Quyền của Others: Không có quyền đọc, ghi hoặc thực thi.

Về mặt cơ chế, mỗi tiến trình trong Linux khi chạy sẽ có hai loại định danh:

- **UID (Real User ID):** Tài khoản thực sự đang gõ lệnh chạy chương trình (ở cấp độ này là tài khoản bandit19).
- **EUID (Effective User ID):** Quyền hạn thực tế mà hệ điều hành cấp cho tiến trình đó khi nó đang hoạt động.

Khi chạy file với lệnh ./bandit20-do

Ở đây, hệ thống thông báo:

“Run a command as another user.”

Điều này cho biết chương trình được thiết kế để thực thi các lệnh với quyền của một user khác.

```
-rwsr-x--- 1 bandit20 bandit19 14880 Jun 24 14:58 bandit20-do
bandit19@bandit:~$ ./bandit20-do
Run a command as another user.
Example: ./bandit20-do whoami
bandit19@bandit:~$
```

Sau khi chạy lệnh:

`./bandit20-do whoami`

hệ thống trả về

bandit20

Điều này cho thấy bandit20-do đang thực thi lệnh whoami với quyền của user bandit20 nhờ cơ chế SetUID. Mặc dù chúng ta vẫn đang đăng nhập với user bandit19, chương trình bandit20-do có thể thực hiện lệnh với quyền của bandit20. Vì vậy, ta có thể sử dụng bandit20-do để thực hiện những lệnh mà bandit19 bình thường không có quyền thực hiện.

Và cũng nhờ việc file được gắn cờ SetUID, khi user bandit19 thực thi file, chương trình sẽ không chạy bằng quyền của người gọi lệnh mà tự động chạy với EUID của chủ sở hữu tệp là user bandit20. Chính nhờ sự "mượn danh" (EUID = bandit20) này, ta có thể sử dụng cú pháp `./bandit20-do cat /etc/bandit_pass/bandit20` để tiến trình vượt quyền và trích xuất thành công mật khẩu của Level 20.

```
-rwsr-x--- 1 bandit20 bandit19 14880 Jun 24 14:58 bandit20-do
bandit19@bandit:~$ ./bandit20-do cat /etc/bandit_pass/bandit20
4pIjcunZ0fK2vmp3IwfG8Vf7VhxD6p0A
bandit19@bandit:~$
```

Bandit Level 20-21

Đầu tiên ta dùng `ls -l` để xem có file gì trong level này

```
bandit20@bandit:~$ ls -l
total 16
-rwsr-x--- 1 bandit21 bandit20 15604 Jun 24 14:58 suconnect
bandit20@bandit:~$ |
```

Ở đây ta thấy một file là `-rwsr-x--- 1 bandit21 bandit20 ... suconnect`

Tên binary của level này: `suconnect` và có chữ `s` có nghĩa `setuid` đang hoạt động

Chạy lệnh `./suconnect` để bật `suconnect`

```
bandit20@bandit:~$ ./suconnect
Usage: ./suconnect <portnumber>
This program will connect to the given port on localhost using TCP. If it receives the correct password from the other side, the next password is transmitted back.
bandit20@bandit:~$ |
```

Do ta chưa nhập số port nên `./suconnect` vẫn chưa thể kết nối được và trả lại password cho ta

Và ta thử cho nó kết nối thử port 12345 với chính port của bandit là 2220 nhưng vẫn không được

```
bandit20@bandit:~$ ./suconnect 12345
Could not connect
bandit20@bandit:~$ ./suconnect 2220
Read: SSH-2.0-OpenSSH_10.2p1
ERROR: This doesn't match the current password!
```

Do đó ta sẽ thử tạo thử 1 cổng 12345 với lệnh `cat /etc/bandit_pass/bandit20 | nc -l 12345` trên cùng ssh Bandit trên một terminal thứ hai

```
bandit20@bandit:~$ cat /etc/bandit_pass/bandit20 | nc -l 12345
bW9kBV5WC3P4yoDyf12LSdGuNz5ka6hY
bandit20@bandit:~$ |
```

Thì nó sẽ kiểm tra password của level trước đó thông qua lệnh `cat /etc/bandit_pass/bandit20` sau đó nó sẽ gửi password mới thông qua `|` (pipe) và `nc` cổng 12345 với lệnh `-l` (listen) mà ta đã tạo trước đó đang chờ lệnh kết nối với `./suconnect 12345` ở Terminal thứ nhất và sau khi ta gõ `./suconnect 12345` thì nó sẽ trả cho ta lệnh password để lên Level tiếp theo ở Terminal thứ 2

```
bandit20@bandit:~$ ./suconnect 12345
Read: 4pIjcunZ0fK2vmp3IwfG8Vf7VhxD6p0A
Password matches, sending next password
bandit20@bandit:~$ |
```

```
bandit20@bandit:~$ cat /etc/bandit_pass/bandit20 | nc -l 12345
bW9kBV5WC3P4yoDyf12LSdGuNz5ka6hY
```

Bandit Level 21-22

Ở Level này, mục tiêu được giấu thông qua cron – một dịch vụ lập lịch trong Linux chuyên dùng để tự động chạy các lệnh hoặc script theo thời gian cấu hình sẵn.

Bandit Level 21 → Level 22

Level Goal

A program is running automatically at regular intervals from **cron**, the time-based job scheduler. Look in **/etc/cron.d/** for the configuration and see what command is being executed.

Commands you may need to solve this level

cron, crontab, crontab(5) (use "man 5 crontab" to access this)

Dựa trên đề bài, ta sẽ dùng lệnh `ls /etc/cron.d/` để tìm file liên quan tới bandit22.

Và ta có được các file như sau:

```
bandit21@bandit:~$ ls /etc/cron.d/
behemoth4_cleanup  cronjob_bandit22  cronjob_bandit24  leviathan5_cleanup  otw-tmp-dir
clean_tmp          cronjob_bandit23  e2scrub_all       manpage3_resetpw_job
```

Kiểm tra thư mục `/etc/cron.d/`, em đọc tệp `cronjob_bandit22` là `cat /etc/cron.d/cronjob_bandit22`

và xác định được cron sẽ tự động gọi script `/usr/bin/cronjob_bandit22.sh` đều đặn mỗi phút dưới quyền của user bandit22. Phân tích nội dung script này, dòng đầu tiên xuất hiện là `#!/bin/bash`.

```
bandit21@bandit:~$ cat /etc/cron.d/cronjob_bandit22
@reboot bandit22 /usr/bin/cronjob_bandit22.sh &> /dev/null
* * * * * bandit22 /usr/bin/cronjob_bandit22.sh &> /dev/null
```

Ở dòng thứ nhất

`@reboot`

Có nghĩa là: mỗi khi hệ thống khởi động thì sẽ chạy command.

bandit22: Đây là user sẽ thực thi command. Tức là script: `/usr/bin/cronjob_bandit22.sh` sẽ được chạy với quyền của bandit22.

`/usr/bin/cronjob_bandit22.sh` là script mà cron sẽ chạy.

`&> /dev/null` có nghĩa là chuyển cả output thông thường và error vào `/dev/null`.

Ở dòng thứ hai

File `/etc/cron.d/cronjob_bandit22` cho biết cron sẽ mỗi phút chạy script `/usr/bin/cronjob_bandit22.sh` với quyền của user bandit22 với từng dấu `*` tượng trưng cho phút, giờ, ngày....

Do đó ta sẽ dùng lệnh `cat /usr/bin/cronjob_bandit22.sh` để đọc cái script này

```
bandit21@bandit:~$ cat /usr/bin/cronjob_bandit22.sh
#!/bin/bash
chmod 644 /tmp/t706lds9S0RqQh9aMcz6ShpAoZKF7fgv
cat /etc/bandit_pass/bandit22 > /tmp/t706lds9S0RqQh9aMcz6ShpAoZKF7fgv
bandit21@bandit:~$ |
```

Khái niệm Shebang: Cụm ký tự `#!` đứng đầu file được gọi là Shebang (hoặc Hashbang). Đây là chỉ thị báo cho hệ điều hành biết phải dùng chương trình thông dịch (interpreter) nào để thực thi đoạn mã bên dưới.

Vai trò của Shebang: Khi có Shebang, hệ thống sẽ tự động gọi đúng môi trường (ở đây là Bash) để chạy kịch bản tron tru. Nếu không có Shebang, hệ thống sẽ không nhận diện được ngôn ngữ lập trình và buộc phải chạy bằng shell mặc định (thường là sh). Việc đoán sai môi trường thực thi này thường dẫn đến các lỗi cú pháp nghiêm trọng nếu script có sử dụng cú pháp nâng cao của Bash, Python hay Perl.

Ở đây ta có thể thấy

`#!/bin/bash` → cho biết script được thực thi bằng Bash.

`chmod 644 ...` → đặt quyền cho file trong `/tmp` thành 644, nghĩa là file có thể được đọc.

`cat /etc/bandit_pass/bandit22 > /tmp/...` → đọc password của bandit22 rồi ghi vào file trong `/tmp`.

Do quá trình cron chạy script bằng user bandit22 và script đọc `/etc/bandit_pass/bandit22` rồi sẽ ghi password vào `/tmp/t706lds9S0RqQh9aMcz6ShpAoZKF7fgv` chính vì vậy tiếp theo ta dùng lệnh `cat /tmp/t706lds9S0RqQh9aMcz6ShpAoZKF7fgv` để đọc password

```
bandit21@bandit:~$ cat /tmp/t706lds9S0RqQh9aMcz6ShpAoZKF7fgv
RYVux2rHEm9tiXHmLFzuR7Vhx6AZQMEz
bandit21@bandit:~$ |
```

Bandit Level 22 → Level 23

Dựa vào đề bài nên ta sẽ dùng lệnh `ls /etc/cron.d/`

Bandit Level 22 → Level 23

Level Goal

A program is running automatically at regular intervals from **cron**, the time-based job scheduler. [Look in /etc/cron.d/](#) for the configuration and see what command is being executed.

NOTE: Looking at shell scripts written by other people is a very useful skill. The script for this level is intentionally made easy to read. If you are having problems understanding what it does, try executing it to see the debug information it prints.

Commands you may need to solve this level

`cron`, `crontab`, `crontab(5)` (use "man 5 crontab" to access this)

```
bandit22@bandit:~$ ls /etc/cron.d/
behemoth4_cleanup  cronjob_bandit22  cronjob_bandit24  leviathan5_cleanup  otw-tmp-dir
clean_tmp          cronjob_bandit23  e2scrub_all       manpage3_resetpw_job
```

Truy cập vào `cronjob_bandit23` do vậy dùng lệnh `cat /etc/cron.d/cronjob_bandit23` để đọc file

```
bandit22@bandit:~$ cat /etc/cron.d/cronjob_bandit23
@reboot bandit23 /usr/bin/cronjob_bandit23.sh &> /dev/null
* * * * * bandit23 /usr/bin/cronjob_bandit23.sh &> /dev/null
bandit22@bandit:~$
```

Tương tự như ở Level trước

Ta dùng lệnh `cat /usr/bin/cronjob_bandit23.sh`

```
bandit22@bandit:~$ cat /usr/bin/cronjob_bandit23.sh
#!/bin/bash

myname=$(whoami)
mytarget=$(echo I am user $myname | md5sum | cut -d ' ' -f 1)

echo "Copying passwordfile /etc/bandit_pass/$myname to /tmp/$mytarget"

cat /etc/bandit_pass/$myname > /tmp/$mytarget
bandit22@bandit:~$ cat /tmp/$mytarget
cat: /tmp/: Is a directory
bandit22@bandit:~$ cat /tmp/$mytarget
cat: /tmp/: Is a directory
bandit22@bandit:~$
```

Ở đây ta có các gợi ý

```
myname=$(whoami)
```

```
mytarget=$(echo I am user $myname | md5sum | cut -d ' ' -f 1)
```



```
echo "Copying passwordfile /etc/bandit_pass/$myname to /tmp/$mytarget"
```

```
cat /etc/bandit_pass/$myname > /tmp/$mytarget
```

myname=\$(whoami) ám chỉ là bandit23 vì cron chạy script với quyền của bandit23 vì vậy
mytarget=\$(echo I am user \$myname | md5sum | cut -d ' ' -f 1) sẽ echo I am user bandit23 |
md5sum | cut -d ' ' -f 1

Do đó chạy: echo I am user bandit23 | md5sum | cut -d ' ' -f 1 sẽ cho ra kết quả

```
bandit22@bandit:~$ echo I am user bandit23 | md5sum | cut -d ' ' -f 1  
8ca319486bfbbc3663ea0fbe81326349  
bandit22@bandit:~$ |
```

Từ đó ta có 8ca319486bfbbc3663ea0fbe81326349 là \$my target từ đó ta sẽ chạy lệnh cat
/tmp/8ca319486bfbbc3663ea0fbe81326349

```
bandit22@bandit:~$ cat /tmp/8ca319486bfbbc3663ea0fbe81326349  
gKXDTAXnIz30BxiPjRZ2uqutU\lPZrBsw  
bandit22@bandit:~$ |
```

Bandit 23-24

Ở level này tương tự như hai level trước ta vẫn sẽ tìm file cron trong `/etc/cron.d/` nhưng khác ở hai level trước đó ta phải tự viết một cái shell script để tìm password

[Donate!](#) [Help?](#)

Bandit Level 23 → Level 24

Level Goal

A program is running automatically at regular intervals from **cron**, the time-based job scheduler. Look in [/etc/cron.d/](#) for the configuration and see what command is being executed.

NOTE: This level requires you to create your own first shell-script. This is a very big step and you should be proud of yourself when you beat this level!

NOTE 2: Keep in mind that your shell script is removed once executed, so you may want to keep a copy around...

Commands you may need to solve this level

`chmod`, `cron`, `crontab`, `crontab(5)` (use "man 5 crontab" to access this)



Chạy lệnh `ls /etc/cron.d/`

```
bandit23@bandit:~$ ls /etc/cron.d/
behemoth4_cleanup  cronjob_bandit22  cronjob_bandit24  leviathan5_cleanup  otw-tmp-dir
clean_tmp          cronjob_bandit23  e2scrub_all       manpage3_resetpw_job
bandit23@bandit:~$ |
```

Ở đây ta dùng lệnh `cat /etc/cron.d/cronjob_bandit24`

```
bandit23@bandit:~$ cat /etc/cron.d/cronjob_bandit24
@reboot bandit24 /usr/bin/cronjob_bandit24.sh &> /dev/null
* * * * * bandit24 /usr/bin/cronjob_bandit24.sh &> /dev/null
bandit23@bandit:~$ |
```

Tương tự như hai level trước đó ta dùng lệnh `cat /usr/bin/cronjob_bandit24.sh`

```

bandit23@bandit:~$ cat /usr/bin/cronjob_bandit24.sh && /dev/null
#!/bin/bash

shopt -s nullglob

myname=$(whoami)

cd /var/spool/"$myname"/foo || exit
echo "Executing and deleting all scripts in /var/spool/$myname/foo:"
for i in * .*;
do
    if [ "$i" != "." ] && [ "$i" != ".." ];
    then
        echo "Handling $i"
        owner="$(stat --format "%U" "$i")"
        if [ "${owner}" = "bandit23" ] && [ -f "$i" ]; then
            timeout -s 9 60 "$i"
        fi
        rm -rf "$i"
    fi
done
bandit23@bandit:~$

```

Đây là script mà cron của bandit24 sẽ tự động chạy.

Theo một tiến trình cron chạy bằng user bandit24 vào /var/spool/bandit24/foo rồi tìm các file, kiểm tra owner sau đó chỉ chạy file owner = bandit23 rồi chạy file đó với quyền hiện tại sau đó xóa file

Do đó ta sẽ thử viết 1 script

```

#!/bin/bash

cat /etc/bandit_pass/bandit24 > /tmp/password

chmod 644 /tmp/password

```

Ở đây

#!/bin/bash có nghĩa là dùng bash

cat /etc/bandit_pass/bandit24 > /tmp/password có nghĩa là đọc password của bandit24 và ghi vào /tmp/password.

chmod 644 /tmp/password có nghĩa cho phép các user khác đọc file.

Dùng lệnh nano /tmp/getpass.sh để tạo script hoặc dùng lệnh printf '%s\n' '#!/bin/bash' 'cat /etc/bandit_pass/bandit24 > /tmp/bandit24_pass' > /var/spool/bandit24/foo/getpass.sh để viết trực tiếp

Sau đó cấp quyền chmod +x /var/spool/bandit24/foo/getpass.sh

```
bandit23@bandit:~$ chmod +x /var/spool/bandit24/foo/getpass.sh
bandit23@bandit:~$ ls -l /var/spool/bandit24/foo/getpass.sh
-rwxrwxr-x 1 bandit23 bandit23 63 Aug 29 12:27 /var/spool/bandit24/foo/getpass.sh
```

Sau đó dùng lệnh `cat /tmp/bandit24_pass` để xem pass

```
bandit23@bandit:~$ cat /tmp/bandit24_pass
hVQMk3lJNsmQ7VF3ubyrNNBom7B0gVXv
```

Bandit Level 24-25

Ở đây yêu cầu ta lấy được mật khẩu cho level bandit25 bằng **cách** thử sai toàn bộ các trường hợp qua cổng 30002.

Ta sử dụng lệnh netcat để tạo kết nối TCP/UDP tới cổng 3002

```
bandit24@bandit:~$ nc localhost 30002
I am the pincode checker for user bandit25. Please enter the password for user bandit24 and the secret pincode on a single line, separated by a space.
```

Ở đây nhập dãy 00 và 0000 nhưng ko đúng mật khẩu của bandit24

```
bandit24@bandit:~$ nc localhost 30002
I am the pincode checker for user bandit25. Please enter the password for user bandit24 and the secret pincode on a single line, separated by a space.

Wrong! Please enter the correct current password and pincode. Try again.
00
Wrong! Please enter the correct current password and pincode. Try again.
```

```
bandit24@bandit:~$ nc localhost 30002
I am the pincode checker for user bandit25. Please enter the password for user bandit24 and the secret pincode on a single line, separated by a space.

Wrong! Please enter the correct current password and pincode. Try again.
00
Wrong! Please enter the correct current password and pincode. Try again.
0000
Wrong! Please enter the correct current password and pincode. Try again.
```

Dựa vào dòng này ta sẽ kết hợp mật khẩu ở level trước đó với 0000

Ví dụ: hVQMk3lJNsmQ7VF3ubyrNNBom7BogVXv 0000

```
bandit24@bandit:~$ nc localhost 30002
I am the pincode checker for user bandit25. Please enter the password for user bandit24 and the secret pincode on a single line, separated by a space.

Wrong! Please enter the correct current password and pincode. Try again.
00
Wrong! Please enter the correct current password and pincode. Try again.
0000
Wrong! Please enter the correct current password and pincode. Try again.
hVQMk3lJNsmQ7VF3ubyrNNBom7BogVXv 0000
Wrong! Please enter the correct current password and pincode. Try again.
hVQMk3lJNsmQ7VF3ubyrNNBom7BogVXv 0000
Wrong! Please enter the correct current password and pincode. Try again.
```

Nhưng lần này đúng format, nhưng 0000 không phải PIN chính xác nhưng Bây giờ ta đã xác nhận format đầu vào là: <password-bandit24> <4-digit-PIN> cho nên mật khẩu để lấy đc pass level này sẽ nằm trong khoảng 0000-9999

Cho nên ta sẽ dùng lệnh nano /tmp/brute.sh

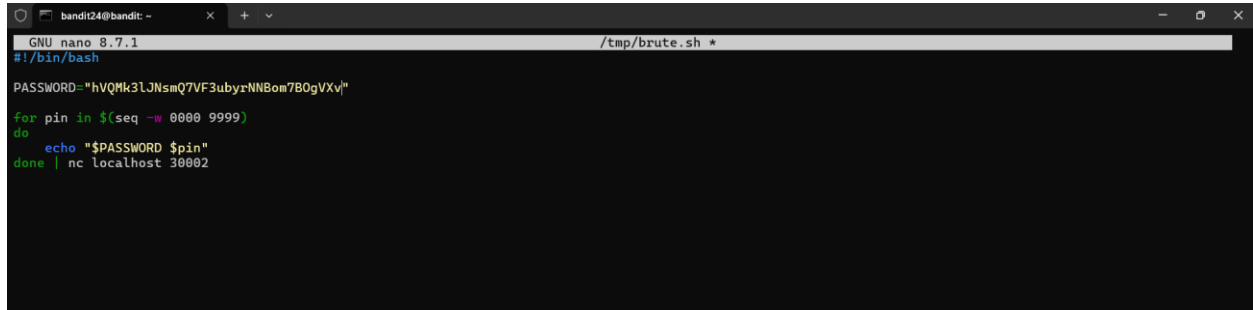
Script ở level này là

```
#!/bin/bash
```

```
PASSWORD="PASSWORD_BANDIT24"
```

```
for pin in $(seq -w 0000 9999)
```

```
do
    echo "$PASSWORD $pin"
done | nc localhost 30002
```



```
bandit24@bandit: ~
GNU nano 8.7.1 /tmp/brute.sh *
#!/bin/bash

PASSWORD="hVQMk3lJNsmQ7VF3ubyrNNBom7BogVXv"

for pin in $(seq -w 0000 9999)
do
    echo "$PASSWORD $pin"
done | nc localhost 30002
```

Ở đây `for pin in $(seq -w 0000 9999)` sẽ tạo lần lượt từ 0000-9999 và nó sẽ in ra :
`hVQMk3lJNsmQ7VF3ubyrNNBom7BogVXv 0000-9999`

Sau đó nó sẽ chuyển toàn bộ output qua port 3002 thông qua lệnh `done | nc localhost 3002` đầu | sẽ đóng vai trò chuyển đổi dữ liệu

Rồi ta cấp quyền thực thi `chmod +x /tmp/brute.sh`

```
bandit24@bandit:~$ chmod +x /tmp/brute.sh
bandit24@bandit:~$ |
```

Sau đó ta kiểm tra file đã có hay chưa

```
bandit24@bandit:~$ ls -l /tmp/brute.sh
-rwxrwxr-x 1 bandit24 bandit24 144 Sep  4 13:21 /tmp/brute.sh
bandit24@bandit:~$ |
```

Sau đó ta sẽ dùng lệnh `bash /tmp/brute.sh` để chạy file

Kết quả sau nhiều tự động thử thì server đã trả đúng password để lên level tiếp theo

```
Wrong! Please enter the correct current password and pincod. Try again.
Correct!
The password of user bandit25 is SoHfqM0EqIX2IYKVciZxvgpR9a2Djx4P
bandit24@bandit:~$ |
```

Bandit Level 25-26

Như đề bài gợi ý nên ta có thể chạy thử lệnh id:

Bandit Level 25 → Level 26

Level Goal

Logging in to bandit26 from bandit25 should be fairly easy... The shell for user bandit26 is not `/bin/bash`, but something else. Find out what it is, how it works and how to break out of it.

NOTE: if you're a Windows user and typically use Powershell to ssh into bandit: Powershell is known to cause issues with the intended solution to this level. You should use command prompt instead.

Commands you may need to solve this level

ssh, cat, more, vi, ls, id, pwd

Lệnh id có thể cho ta biết

UID

GID

các group của user hiện tại.

```
bandit25@bandit:~$ id
uid=11025(bandit25) gid=11025(bandit25) groups=11025(bandit25)
bandit25@bandit:~$ |
```

Tiếp đó ta chạy thử lệnh pwd để biết ta đang ở thư mục nào

```
bandit25@bandit:~$ pwd
/home/bandit25
```

Rồi ta chạy ls để xem có file gì trong server này và ta thấy có một sshkey để đang đăng nhập vào bandit 26

```
bandit25@bandit:~$ ls
bandit26.sshkey
bandit25@bandit:~$ |
```

Sau đó dùng lệnh cat và grep để đọc các dòng nội dung liên quan bandit26

cat /etc/passwd | grep '^bandit26:'

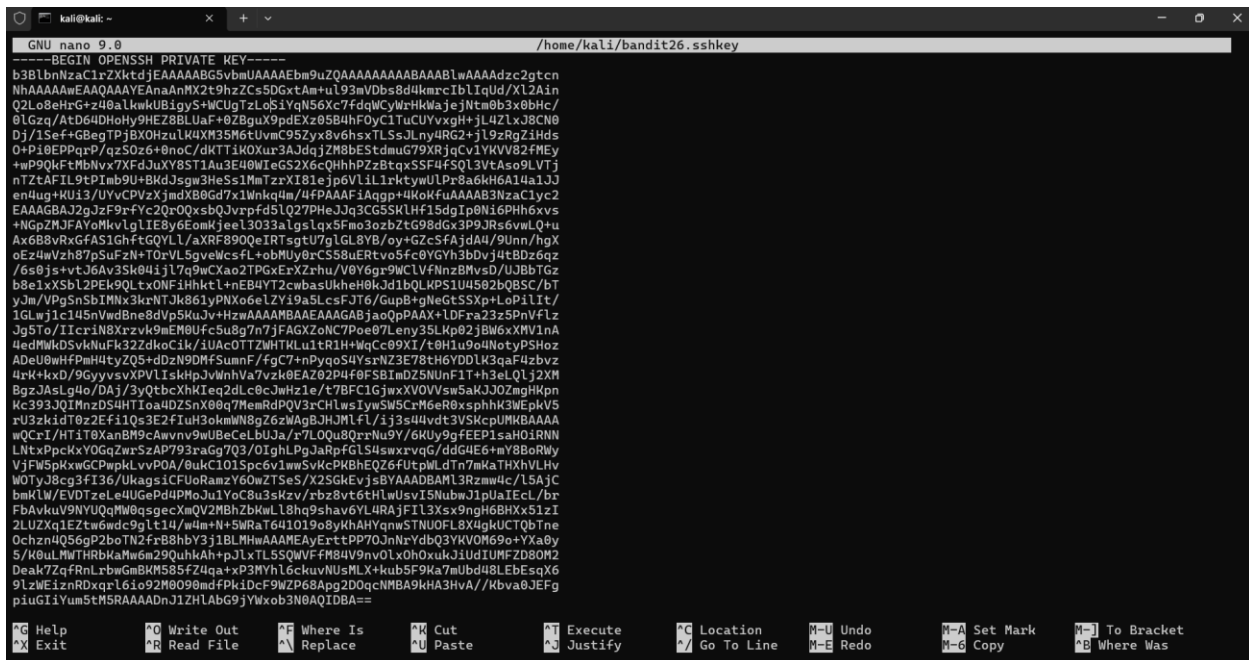
```
bandit25@bandit:~$ cat /etc/passwd | grep '^bandit26:'
bandit26:x:11026:11026:bandit level 26:/home/bandit26:/usr/bin/showtext
bandit25@bandit:~$ |
```

cat /etc/passwd dùng để đọc file chứa thông tin các user. Dấu | chuyển nội dung đó cho grep, còn grep '^bandit26:' lọc ra đúng dòng của user bandit26. Phần cuối của dòng cho biết login shell mà bandit26 đang sử dụng.

để xem private key ta dùng lệnh cat bandit26.sshkey

```
bandit25@bandit:~$ cat bandit26.sshkey
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZktkdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAAABlAAAAAdzc2gtcn
NhAAAAEAQAAAYAnaAMXZt9hzZC5SDGxtAm+uL93mVDbs8d4kmrcIbLIqUd/XL2Ain
Q2L0eHrG+z40alkwkUBigyS+WCUGtZL0SiYqN56Xc7fdqWcyWrHkWaJeJNtm0b3x0bHc/
0LGzq/AtD64DHoHy9HEZ8BLUaF+0ZBguX9pdEXz05B4hF0yC1TuCuYvxgH+jL4ZLxJ8CN0
Dj/1Sef+GBegTPjBXOHzuLk4Xm35M6tUvmC95Zyx8v6hsxTlSsJLny4RG2+jL9zRgZ1Hds
O+p1EPPqP/qzSOz6+0noC/dKTTiK0Xur3AJdgjZM8bEstdmuG79XRjqCv1YKVVB2fMEy
+np9QkFmbNvx7XfdJuxY8ST1Au3E40WIEGS2X6cQHhHPZBtqxSSF4fS0L3VtAso9LVTj
nTZtAFIL9tPImb9U+BkdJsgw3HeSs1MmTzrXI81ejp6VLiL1rkywULPr8a6kH6A14a1J3J
en4ug+KUi3/UYvCPVxJmdXB0Gd7x1Wnkq4m/4fPAAAFiAqpp+4KoKfuaAAAB3NzaC1yc2
EAAAAGBAJ2gJzF9rYc2Qr0QxsbdQJvvpfd5LQ27PHeJJq3CGSSKLHF15dgIp0Ni6PHh6xvs
+NGpZMJAfAYoMkvLglIE8y6EomKjeeL3033a1gslqx5Fmo3ozbZtG98dGx3P9JR6vwmLQ+u
Ax6B8vRgFAS1GhftGQYL/aXRF890QeIRTsgtU7g1GL8YB/oy+GZcSfAj4A/9Unn/hgX
oEzHwzh87pSuFzN+T0rVL5gveWcsfL+obMuy0rCS58uERtvo5fc0YGyh3bDvj4tBDz6qz
/6s0js+vtJ6Av3Sk04ij17g9wCXao2TPGxErXZrhu/V0Y6gr9WCLVfNnz8BmvsD/UJ3BtGz
b0e1xXsbl2PEk9QLtxONF1HhktL+nEB4YT2cwbAsUkheH0Kjd1bQLKPSIU4502b0BSC/bT
yJmYPgSnSbIMNix3krNTJk861yPNXo6eLZYi9a5LcsFJT6/GupB+gNeGtSSXp+LoPiIt/
1GLwj1c145NvmdBne8dVp5KuJv+HzwAAAAABAAEAAAGABjaoQpPAAAX+LDFra23z5PnVfLz
Jg5To/Iicr1N8rzvk9mEM0Ufc5u8g7n7jFAGXZ0NC7Poe07Leny35LKp02jBW6xXWm1nA
4edMwkdSVkNuFk32ZdkoCik/iUAO-TTZWHTKLu1tR1H+WqC09XI/t0H1u9o4N0tyPSHoz
Ad0eUwHfPmH4tyZQ5+dDzN9DMfSummF/fgc7+nPyqoS4YsrNZ3E78tH6YDDLK3qaF4zbvz
4rK+Kxkd/9GyyvsvXPVLiSkHpfJvNhVa7vzk0EAZ02P4f0FSBImDZ5NUnF1T+h3eLq1J2XM
BgZJASLg4o/DAj/3yQtbcXhKIeq2dLc0cJwHz1e/t7BFC1GjwxXVOVsw5aKJJO2mgHKpn
Ck393JQImnzDS4HTIoa4DZ5nX00q7MemRdPQV3rCHLwsIywSW5CtM6eR0xsphhK3WEpkV5
rU3zkIdT0z2Ef11Qs3E2f1uH3okmW8gZ6zWAgBJHJMLfLij3s44vdt3VSKcpUMKBAAAA
wQcIjHT1T0XanBM9cAwvnn9wUBeCLeBuJa/r7LQ0u0QrrNu9Y/6KUY9gFEFP1saH01RNN
LntXpckXxYOGqZwrS2AP793raGg7Q3/OIghLPgJaRpfGLS4swxvqG/ddG4E6+mY8BoRMy
VJfW5pKxwGCPwplkvvPOA/0ukC101Sp6v1mwSvKcPKBhEQZ6FutpWLDtn7mKaTHXhVhV
W0TyJ8cg3f136/Ukags1CFUoRamzY60wZTSeS/X2SGKevjsBYAAADBAH13Rzmw4c/L5AJC
bmKw/EVDtZLe4UgePd4PmoJu1YoC8u3sKzv/rbz8vt6tHlwUsvISNubwJ1pUaIEcl/br
FbAvkuV9NYUqQmW0sgscXmQV2MbH2bKwL18hq9shav6YL4RAjF1L3Xsx9ngH6BHx51Z1
2LUZXq1EZtw6dc9glt14/w4m+N5WRaT641019o8yKHAHYqnmSTNUOFL8X4gkUcQTbTne
OchznQ56gP2boTn2fR8BhY3j1BLMwAAAMEAYertPP70JnNrxYdbQ3YKvOM69o+YXa8y
5/K0uLmWTHRbKaMw6m29UqhK+h+pJLxTL5SQWVFm84V9nv0Lx0h0xukJiUdIUMFZD80M2
Deak7ZqFrnLrbwGkBM585fZ4qa+P3MYhL6ckuvNMSLX+kub5F9Ka7mUbd48LEbEsqX6
9LzWEiznRDXqrL6io92M809mdfPkIdCF9WZP68Agp2D0qcNMBa9kHA3HvA//Kbva03JFg
pIuGIiYumStMSRAAADnJ1ZH1AbG9jYmXob3N8AQIDBA==
-----END OPENSSH PRIVATE KEY-----
bandit25@bandit:~$
```

Sau đó sao chép toàn bộ và tạo 1 file key khác trên máy với nano ~/bandit26.sshkey



Sau đó cấp quyền cho file key này

chmod 600 ~/bandit26.sshkey

Sau đó đăng nhập vào bandit26 với lệnh `ssh -i ~/.bandit26.sshkey bandit26@bandit.labs.overthewire.org -p 2220` nhưng server đăng nhập thành công nhưng đóng lại ngay lập tức

Thì ở đây ta sẽ định dạng số cột mà terminal sẽ xuất hiện

```
stty rows 5
```

```
(kali㉿kali)-[~]  
$ stty rows 5  
  
(kali㉿kali)-[~]  
$ stty size  
5 156
```

Nhấn v sẽ mở nội dung hiện tại bằng trình soạn thảo vi. Trong vi thì : để mở command mode gõ lệnh :set shell=/bin/bash

```
:set shell=/bin/bash
```

[1,3](#) [Top](#)

Sau đó gõ: `:shell` với mục đích là yêu cầu vi mở một Bash shell

[illegible]

Gõ lệnh whoami để test

```
| '_ \ / _ | '_ \ / _ | '_ \ / _ | '_ \ / _ | '_ \ / _ |
:shell
bandit26@bandit:~$ whoami
bandit26
bandit26@bandit:~$ |
```

Gõ lệnh pwd để kiểm tra mình đang ở thư mục nào

```
bandit26@bandit:~$ pwd
/home/bandit26
bandit26@bandit:~$ |
```

Dùng lệnh id để xem các id hiện tại

```
bandit26@bandit:~$ id
uid=11026(bandit26) gid=11026(bandit26) groups=11026(bandit26)
bandit26@bandit:~$ |
```

Dùng lệnh ls -la để kiểm tra tất cả các file có trong server

```
bandit26@bandit:~$ ls -la
total 44
drwxr-xr-x  3 root    root    4096 Jun 24 14:59 .
drwxr-xr-x 150 root    root    4096 Jun 24 15:02 ..
-rw-r--r--  1 root    root     220 Feb 13  2026 .bash_logout
-rw-r--r--  1 root    root    3851 Jun 24 14:50 .bashrc
-rw-r--r--  1 root    root     807 Feb 13  2026 .profile
drwxr-xr-x  2 root    root    4096 Jun 24 14:59 .ssh
-rwsr-x---  1 bandit27 bandit26 14880 Jun 24 14:59 bandit27-do
-rw-r-----  1 bandit26 bandit26  258 Jun 24 14:59 text.txt
bandit26@bandit:~$ |
```

Ở đây ta thấy có file bandit27-do nên ta sẽ chạy lệnh ./bandit27-do

```
bandit26@bandit:~$ ./bandit27-do
Run a command as another user.
Example: ./bandit27-do id
bandit26@bandit:~$ |
```

Nhưng ví dụ ta sẽ chạy thử lệnh ./bandit27-do id để kiểm tra id

```
bandit26@bandit:~$ ./bandit27-do id
uid=11026(bandit26) gid=11026(bandit26) euid=11027(bandit27) groups=11026(bandit26)
bandit26@bandit:~$ |
```

Ta có thể thấy

uid=11026(bandit26)	User thực sự đang chạy lệnh là bandit26
gid=11026(bandit26)	Group hiện tại là bandit26
euid=11027(bandit27)	Effective UID là bandit27
groups=11026(bandit26)	User hiện tại thuộc group bandit26

Chúng ta có thể thấy kết quả cho uid=bandit26 nhưng euid=bandit27. Điều này chứng minh bandit27-do có SetUID: người thực thi vẫn là bandit26, nhưng chương trình sử dụng effective UID của bandit27 khi thực hiện lệnh.

Sau đó ta dùng thử lệnh `./bandit27-do cat /etc/bandit_pass/bandit27` để xem pass để lên level tiếp theo

`./bandit27-do cat /etc/bandit_pass/bandit27`

```
bandit26@bandit:~$ ./bandit27-do cat /etc/bandit_pass/bandit27
STJLJBRRphMxKB392CT4i0r5CzbzPU9ER
bandit26@bandit:~$ |
```

Bandit level 26-27

Bandit Level 26 → Level 27

Level Goal

Good job getting a shell! Now hurry and grab the password for bandit27!

Commands you may need to solve this level

ls

Chính là password mà ta lấy được ở level trước đó là
STJLJBRRphMxKB392CT4iOr5CbzPU9ER

Bandit level 27-28

Bandit Level 27 → Level 28

[Donate!](#) [Help?](#)

Level Goal

There is a git repository at `ssh://bandit27-git@bandit.labs.overthewire.org/home/bandit27-git/repo` via the port 2220. The password for the user `bandit27-git` is the same as for the user `bandit27`.

From your local machine (not the OverTheWire machine!), clone the repository and find the password for the next level. This needs git installed locally on your machine.

Commands you may need to solve this level

git

Helpful Reading Material

Installing Git
Git from the Bottom Up

Ở Đề bài này Git có nghĩa là hệ thống quản lý phiên bản (Version Control System), dùng để theo dõi lịch sử thay đổi của mã nguồn và file trong một project.

Repository có thể chứa:

- code
- file
- lịch sử thay đổi
- commit
- branch

Ngoài ra đề bài cũng đề cập là ta ko truy cập vào `ssh bandit27@bandit.labs.overthewire.org -p 2220` do đó ta tạo một thư mục tạm thời trong `/tmp` ở máy

```
(kali㉿kali)-[~]  
$ mkdir /tmp/dang
```

Truy cập vào thư mục vừa mới tạo

```
(kali㉿kali)-[~]  
$ cd /tmp/dang
```

Sao chép password ở level trước đó bằng lệnh `echo`

`“STJLJBRRphMxKB392CT4iOr5CbzPU9ER” > pass.txt` tạo ra file `pass.txt` và kiểm tra file đã có hay chưa

```
(kali㉿kali)-[/tmp/dang]  
$ echo “STJLJBRRphMxKB392CT4iOr5CbzPU9ER” > pass.txt
```

```
(kali㉿kali)-[/tmp/dang]
$ ls
pass.txt
```

Tiếp đó ta sao chép một Git repository từ xa về máy bằng lệnh `git clone ssh://bandit27-git@bandit.labs.overthewire.org:2220/home/bandit27-git/repo` rồi nhập pass ở level trước đó vào (nên nhớ chỉ định cổng server 2220 thì mới truy cập vào được)

[illegible][illegible]

Dòng Receiving objects: 100% (3/3), done có nghĩa là Git đã tải toàn bộ repository về máy. Dùng lệnh ls để kiểm tra lại thư mục ta vừa mới tạo khi này

```
(kali㉿kali)-[/tmp/dang]
$ ls
pass.txt  repo
```

Lúc này đã có 1 thư mục mới tên là repo sau đó ta di chuyển vào thư mục repo và dùng lệnh ls kiểm tra có file nào trong thư mục ko thì ta thấy được file README

```
(kali㉿kali)-[/tmp/dang]
$ cd repo

(kali㉿kali)-[/tmp/dang/repo]
$ ls
README
```

Sau đó ta dùng lệnh cat README để đọc file README

```
(kali㉿kali)-[/tmp/dang/repo]
$ cat README
The password to the next level is: y8Yd2ssKcpHpud7Uv0SOxwamRMzIGIeQ
```

Y chang đề bài trước, ta tạo một thư mục tạm thời

Truy cập vào thư mục ta vừa mới tạo

Sao copy pass ở thư mục trước vào file pass.txt

Sau đó sao chép một Git repository từ xa về máy bằng lệnh `git clone ssh://bandit28-git@bandit.labs.overthewire.org:2220/home/bandit28-git/repo` rồi nhập pass ở level trước đó vào

Dùng lệnh `ls` để kiểm tra thư mục repo đã sao chép thành công hay chưa

[illegible]

Dùng lệnh `cd` để di chuyển vào mục repo và dùng `ls` để kiểm tra các file có trong thư mục repo

```
(kali㉿kali)-[/tmp/dang1]
$ cd repo

(kali㉿kali)-[/tmp/dang1/repo]
$ ls
README.md
```

Dùng lệnh `cat README.md` để đọc file

```
(kali㉿kali)-[/tmp/dang1/repo]
$ cat README.md
# Bandit Notes
Some notes for level29 of bandit.

## credentials

- username: bandit29
- password: xxxxxxxxxxxx
```

Khác ở Level trước thì lần này pass đã bị xóa và như đã đề cập ở Level trước thì Repo có thể chứa code, file, lịch sử thay đổi file hay branch... và Git chính là hệ thống để xem, quản lý, theo dõi lịch sử chỉnh sửa của repo và ta có lệnh git như sau

Lệnh	Chức năng
-------------	------------------

git clone	Clone repository
git branch -a	Xem tất cả branch
git checkout	Chuyển branch
git switch	Chuyển branch
git log	Xem lịch sử các chỉnh sửa
git show	Xem các chỉnh sửa

Do đó dùng lệnh git log và git show để kiểm tra lịch sử chỉnh sửa

```
(kali㉿kali)-[/tmp/dang1/repo]
$ git log
commit 83d77407b76c9f86ac4e691a47618641c9d527ba (HEAD -> master, origin/master, origin/HEAD)
Author: Morla Porla <morla@overthewire.org>
Date:   Wed Jun 24 14:59:06 2026 +0000

    fix info leak

commit 13bbc4d2414ffe0439b8ee4f5e5c2949780cf4b3
Author: Morla Porla <morla@overthewire.org>
Date:   Wed Jun 24 14:59:06 2026 +0000

    add missing data

commit f3334fbccbf9446a6af88a3c71021c2f57163322
Author: Ben Dover <noone@overthewire.org>
Date:   Wed Jun 24 14:59:06 2026 +0000

    initial commit of README.md

(kali㉿kali)-[/tmp/dang1/repo]
$ git show
commit 83d77407b76c9f86ac4e691a47618641c9d527ba (HEAD -> master, origin/master, origin/HEAD)
Author: Morla Porla <morla@overthewire.org>
Date:   Wed Jun 24 14:59:06 2026 +0000

    fix info leak

diff --git a/README.md b/README.md
index 42331d9..5c6457b 100644
--- a/README.md
+++ b/README.md
@@ -4,5 +4,5 @@ Some notes for level29 of bandit.
 ## credentials

- username: bandit29
-- password: Em7eGtqaMySwNFjCpwzzHhLhospOcdt0
+- password: xxxxxxxxxxxx
```

Ở đây ta có thể thấy khi dùng git log để xem lịch sử chỉnh. Chỉnh sửa mới nhất có tên fix info leak và khi ta dùng git show cho thấy ở đây, password cũ là

Em7eGtqaMySwNFjCpwzzHhLhospOcdt0 đã bị thay bằng xxxxxxxxxxxx.

Tương tự ở Level trước ta tạo một thư mục và di chuyển vào thư mục đó và tạo file pass.txt

Rồi dùng ls để kiểm tra

Sau đó dùng lệnh git clone `ssh://bandit29-git@bandit.labs.overthewire.org:2220/home/bandit29-git/repo` để sao chép repo về máy

Tiếp đó ta dùng ls để kiểm tra có thư mục repo hay chưa

Sau khi di chuyển vào thư mục Repo và dùng lệnh ls để tìm file README.md và dùng lệnh cat để đọc thì ta thấy password ko có hiển thị

```
(kali㉿kali)-[/tmp/dang2/repo]
$ cat README.md
# Bandit Notes
Some notes for bandit30 of bandit.

## credentials

- username: bandit30
- password: <no passwords in production!>

(kali㉿kali)-[/tmp/dang2/repo]
$ |
```

Dùng git branch -a để các phiên bản của file README.md

Ở đây ta có

```
(kali㉿kali)-[/tmp/dang2/repo]
$ git branch -a
* master
  remotes/origin/HEAD -> origin/master
  remotes/origin/dev
  remotes/origin/master
  remotes/origin/splotts-dev
```

Master là bản chính thức là bản mà ta xem hiện tại

Dev là bản phát triển

Sau đó ta dùng lệnh git show lần lượt từ HEAD cho splotts-dev

```

(kali㉿kali)-[/tmp/dang2/repo]
$ git show origin/HEAD
commit a9c5d1c2b43890809f3077bb9ec65c30ced242fb (HEAD -> master, origin/master, origin/HEAD)
Author: Ben Dover <noone@overthewire.org>
Date:   Wed Jun 24 14:59:08 2026 +0000

    fix username

diff --git a/README.md b/README.md
index 2da2f39..1af21d3 100644
--- a/README.md
+++ b/README.md
@@ -3,6 +3,6 @@ Some notes for bandit30 of bandit.

## credentials

-- username: bandit29
+- username: bandit30
- password: <no passwords in production!>

(kali㉿kali)-[/tmp/dang2/repo]
$ git show origin/dev
commit d36874ce7e88201c326bb596ba47a4cd063a023e (origin/dev)
Author: Morla Porla <morla@overthewire.org>
Date:   Wed Jun 24 14:59:08 2026 +0000

    add data needed for development

diff --git a/README.md b/README.md
index 1af21d3..d395d04 100644
--- a/README.md
+++ b/README.md
@@ -4,5 +4,5 @@ Some notes for bandit30 of bandit.

## credentials

- username: bandit30
-- password: <no passwords in production!>
+- password: jq9Dfg2rXsfYsWMgFuKlXhphjdH7UsgX

```

ở mục dev ta thấy pass trước đó là jq9Dfg2rXsfYsWMgFuKlXhphjdH7UsgX nhưng sau đó đã bị chỉnh sửa ở mục master

TP. Hồ Chí Minh, ngày 08 tháng 09 năm
2026

Người thực hiện

HẢI ĐĂNG